Vistula University

The Faculty of Computer Engineering, Graphic Design and Architecture

Program of study Computer Science

Nnamdi Isaac Alor

Student number 73207

DESIGN AND IMPLEMENTATION OF A SIMULATION-BASED FRAMEWORK FOR SOCIAL ENGINEERING ATTACK DETECTION AND DEFENSE

The master's thesis

written under the supervision of

Dr inż. Igor Protasowicki

Warsaw, 2026

Table of Contents

Contents

Table of Contents ii
List of Tables iv
INTRODUCTION 2
Subject of the Study 3
Main Objective of the Research 3
Specific Objectives 3
Main Research Problem 4
Specific Problems 4
Leading Hypothesis 4
Sub-Hypotheses 4
Multifaceted Approach 4
Sources of Information 5
Research Methods 5
Structure of the Work 5
CHAPTER ONE: GENERAL BACKGROUND AND CONCEPTUAL FOUNDATION 7
1.1 Understanding Social Engineering in the Age of Digital Vulnerability 7
1.2 The Human Dimension of Cybersecurity: Behaviour, Training, and Evolving Practices 10
1.3 Simulation as a Strategic Tool for Cybersecurity Awareness and Defense 15
CHAPTER TWO: PROJECT SCOPE, TECHNOLOGIES, AND METHODOLOGICAL FOUNDATIONS 19
2.1 Foundations and Scope of the Simulation-Based Cybersecurity Framework 20
2.2 System Architecture and Technological Infrastructure of the Simulation Framework 21
2.3 Methodological Approach and Practical Applicability 23
CHAPTER THREE: END-USER CHARACTERISTICS, EXPECTATIONS, AND COST ANALYSIS 25
3.1 End-User-Centered Orientation and Practical Foundations for Framework Deployment 25
3.2 User Expectation 26
3.3 Cost Analysis and Justification 27
CHAPTER FOUR: PROJECT DOCUMENTATION AND DESIGN 30
4.1 System Architecture and Simulation Workflow 30

4.2 Use Case Analysis and Interaction Design 33
4.2.1 System Actors and Roles 33
4.2.2 Fundamental Applications of the Framework 34
4.2.3 Interaction Flow and Sequence Design 36
4.2.4 Role of Use Case Modelling in System Design 37
4.3 Data Model and Database Schema 37
4.3.1 Data Persistence Requirements and Modelling Approach 37
4.3.2 Data Core Data Entities and Relationships 38
4.3.3 Description of the Database Schema 39
4.3.4 Role of the Data Model in System Evaluation and Extensibility 40
4.4 Component and Module Architecture 40
4.5 Interface and API Design 43
4.6 Implementation Details 45
4.7 Environment, Deployment and Configuration. 48
4.8 Detection Logic, Testing and Evaluation 49
4.8.1 Experimental Setup and Metrics 49
4.8.2 Quantitative Results 52
4.9 Chapter Summary 52
CHAPTER FIVE: CONCLUSION AND FUTURE WORK 54
5.1 Answer to the Main Research Problem 54
5.2 Verification of Hypotheses 54
5.3 Contribution of the Study 55
5.4 Limitations 55
5.5 Directions for Future Work 55
BIBLIOGRAPHY 56

List of Tables

Table	Page No.
3.1: Estimated Cost	26
4.1: Summary of Experimental Results	50

List of Figures

Figure **Page No.**

4.1: The System Architecture diagram for a visual summary 28

4.2: Phishing Attack Workflow Diagram 29

4.3: USB Attack Workflow Diagram 30

4.4: Use Case Diagram of the Simulation-Based Cybersecurity Framework 33

4.5: Sequence Diagram for. Phishing Simulation Scenario 35

4.6: Entity Relationship Diagram of the Simulation-Based Cybersecurity Framework 37

4.7: Component Diagram of the Simulation-Based Cybersecurity Framework 41

INTRODUCTION

Protecting against malicious activities designed to interfere with the confidentiality, integrity, and availability of data is a significant role of any modern cybersecurity system. Social engineering attacks have become one of the most significant cyber threats, as they exploit human weaknesses rather than technical vulnerabilities (Syafitri *et al*., 2022, p. 4). These attacks attempt to extract confidential information, gain unauthorized access, or compromise security in other ways. Popular ones include phishing emails, pretexting, baiting, and spear-phishing, which employ the aspects of trust and curiosity, rather than technical exploits (Alkhalil *et al*., 2021, p. 7).

Social engineering Attacks have become more frequent and highly sophisticated over the past decade due to technological advances, the proliferation of social media, and the exposure of personal information online. According to reports by international cybersecurity companies, human error continues to be a significant contributor to more than 90 per cent of security breaches (Fuertes, 2022). The dire requirement is fraught with this intensity to have effective detection and defense components that are beyond the repertoire of traditional antivirus and firewall protection strategies. Although most organizations have emphasized the preventive aspect, there is increasing realization of the fact that proactive detection, in conjunction with specific training and simulation, might limit vulnerability to such attacks (Salman & Alsajri, 2023, p. 3).

The advantages of simulation-based methods in training and testing of specific systems in cybersecurity showed that they are effective methods of training and testing/examining, since they can safely simulate real-life attack scenarios without any damage propagating. It is possible to test the defense mechanisms of organizations, train the employees, and evaluate the detection systems using a simulated environment of social engineering attacks. Nevertheless, the available academic and practical research can barely be used to fix the technical aspects of the development and implementation of a special simulation-based framework as a consistent and flexible approach to detecting and preventing attacks of social engineering (Kavak *et al*., 2021, p. 9).

This study is thus concerned with the design of this type of framework, which combines the use of simulation models, detection algorithms, and response procedures. The progress of this research should help ensure that an organization assesses its security posture, identifies weaknesses, and enables the upgrade of safeguards against human-centered cyber threats.

The main hypothesis of the current research is that a simulation-based model, when constructed and executed in the most appropriate manner, will contribute to the detection and countermeasures

of social engineering attacks in a substantial way. The hypothesis is based on the premise that experiential learning and real-time feedback mechanisms may help to decrease the vulnerability of the users to manipulation and enhance the resilience of an organization. The framework will be viable as it will incorporate realistic attack scenarios and automated detection and action to respond to the attack, thus providing a comprehensive way to train and protect against cybercrimes.

In the preparation of this diploma thesis, artificial intelligence (AI)–based tools were used in a limited and supportive capacity. These tools assisted primarily with language refinement, grammar correction, and improvement of academic clarity and coherence during the drafting process. The conceptualization of the research topic, formulation of objectives and hypotheses, selection of research methods, analysis, interpretation of results, and final academic judgments remain entirely the work of the author. AI tools were not used to generate original research data, conduct experiments, or make analytical conclusions. The use of AI was strictly aligned with institutional academic integrity guidelines.

Subject of the Study

The subject of the research is**:**

Development of a simulation-based framework that can be used to mimic social engineering attacks and includes detection and defensive measures to achieve better preparation against cyber attacks.

Main Objective of the Research

The objective is:

To design and implement a simulation-based framework that can detect and defend against social engineering attacks.

Specific Objectives

The specific objectives stem from and are subordinated to the main objective. Among the specific objectives are:

1. To review and categorize common social engineering attack techniques.
2. To design a simulation environment that can replicate selected attack scenarios.
3. To develop and integrate detection and defense mechanisms within the framework.
4. To test and evaluate the framework's performance using defined security metrics.

Main Research Problem

The main research problem is:

What are the best practices to design and implement an effective simulation-based framework to detect and prevent social engineering attacks?

Specific Problems

1. What are the most prevalent social engineering attack techniques and their characteristics?
2. How can these attacks be accurately simulated in a controlled environment?
3. What detection and defense mechanisms can be integrated into the framework for optimal effectiveness?
4. How effective is the developed framework in mitigating simulated social engineering attacks?

Leading Hypothesis

A simulation-based framework, designed to replicate social engineering attack scenarios, can significantly enhance detection and defense capabilities, thereby reducing the likelihood of successful attacks.

Sub-Hypotheses

H1. Comprehensive identification of attack types will improve simulation accuracy.
H2. A well-designed simulation environment will facilitate realistic testing of detection systems.
H3. Integrated detection and defense mechanisms will improve organizational readiness.
H4. The framework will demonstrate measurable improvement in attack mitigation during testing.

Multifaceted Approach

Approach to the topic of work is manifold, as, on the one hand, the theme of work is the concern and expertise of the author in questions of cybersecurity systems, and on the other hand, it is preceded by the gathering and reviewing of related literature. This is despite social engineering attacks having been extensively researched regarding the general awareness of security. Relatively little to no research has been dedicated to simulation-based frameworks that integrate replications of the actual attack as well as automated detection and defense. The gap in the research explains the significance of this subject.

One of the key factors that preconditioned the appearance of new publications was increasing interest in issues of human-factor vulnerabilities in the sphere of cybersecurity. In particular, the studies by Lugo *et al*. (2023) and Khadka & Barkat Ullah (2025) are noteworthy because they state that real-world simulations are essential in enhancing user awareness and the need to have proactive defense against human-oriented cyber threats, respectively.

Sources of Information

The following categories of source materials formed the basis for the development of the topic:

i. Academic journals and conference proceedings on cybersecurity and social engineering.
ii. Technical reports and industry white papers on simulation-based security testing.
iii. Cybersecurity training manuals and frameworks.
iv. Case studies of real-world social engineering attacks and defenses.

Research Methods

The methods of the research were defined by the primary goal and issue that was addressed. This study is an analytical-empirical research that employs:

Simulation Modeling – A Model that is applied to simulate scenarios of a real attack, but in a controlled environment to design and implement.

Experimental testing- This was used to assess the framework in terms of detection and defense of attacks.

Comparative Analysis: It will be used to compare the proposed framework with existing approaches regarding accuracy, detection rate, and efficiency.

When developing the topic, simulation modeling was the main research technique employed to create the attack scenarios, such as phishing and baiting, to test. The second approach of evaluating the framework under experimental testing was adopted to determine the accuracy and response time. In its turn, it was conducted by comparative analysis to obtain some improvements in the existing training and detection systems of the security provided.

Structure of the Work

The identified objectives, research problems, and hypotheses guided the division of the work into five main chapters, in addition to the introduction.

Chapter One provides a detailed background of social engineering attacks, their classifications, and existing mitigation strategies.

Chapter Two reviews related literature, theoretical foundations, and existing simulation-based security solutions.

Chapter Three describes the methodology, including the system architecture, simulation setup, and evaluation metrics.

Chapter Four presents the implementation of results, performance analysis, and discussion of findings.

Chapter Five provides a detailed general conclusion of the thesis which includes; Answers to main research problem, Verification of Hypotheses, Limitation and Directions for Future work.

CHAPTER ONE: GENERAL BACKGROUND AND CONCEPTUAL FOUNDATION

1.1 Understanding Social Engineering in the Age of Digital Vulnerability

The swift growth of information and communication technologies has radically changed the way societies, businesses, and individuals go about the creation and exchange of value. In the modern digital world, information is now among the most valuable commodities, and it is the source of innovation, governance, as well as economic development. Nevertheless, it is the very transformation that enables organizations to pose new and complicated security problems. The human element is now a major vulnerability to cybersecurity as the confidentiality, integrity, and availability of data now take center stage in the context of advanced technologies, including firewalls, intrusion detection systems, as well as antivirus software. Human psychology has remained the most vulnerable point of security through which cybercriminals take advantage of the weak side of human nature, without targeting technical vulnerabilities. This is a type of attack called social engineering, where deception and persuasion are used to manipulate individuals into getting confidential data or systems. Folorunso *et al*. (2024, p. 2) observe that social engineering attacks are the most deceitful and often successful type of cybercrime as they represent human nature that includes tendencies to trust, to be curious, and to be helpful. Hence, even the most sophisticated technologies may be brought to nil in case of the absence of human awareness and vigilance.

It is this that poses the paradox of digitalization; society has made an unprecedented advancement in technological innovation, and it has made people more vulnerable at the same time. Organizations have embedded stronger security at the system level, but attackers always circumvent the defenses by focusing on the human mind. Consequently, cybersecurity should not be considered exclusively as a technical solution, but it has to incorporate the social and

psychological aspects of human behavior. One of the significant strategies in this context has been simulation-based learning, whereby, under the control of simulated attacks, individuals can get to experience and react to the attack without the actual effects of the attacks in real life. This type of practice converts theoretical knowledge into subconscious awareness to enable people to enhance their skill of perceiving manipulation and resisting it.

The act of deception, manipulation, or psychological influence to obtain unauthorized access to information, systems, or assets without objections can be referred to as social engineering (Syafitri *et al*., 2022, p. 4). Social engineering is not based on software weaknesses, as malware or brute-force attacks are, but rather on human nature. Victims usually fall prey to tricks to take actions that may endanger security, like disclosing passwords, clicking on dangerous links, or downloading virus-infested files. Siddiqi *et al*. (2022, p. 6) underline that the dependence of social engineering on human psychology complicates this method, especially in terms of detecting or preventing an attack, because most of the time, the victim is inadvertently a co-conspirator of the attack.

As stated by Alkhalil *et al*. (2021, p. 7), there are two general categories of social engineering: direct and indirect. Direct techniques require personal contact with the target, including phishing emails or scam messages and calls, or face-to-face tricks, but indirect techniques refer to digital objects such as malicious USB devices or fake websites that the victim encounters without any external assistance. Popular examples are phishing, spear-phishing, pretexting, baiting, and quid pro quo. In phishing, email messages are sent by fraudsters pretending to represent authentic organizations to obtain personal information like passwords or financial information. Spear-phishing is a form of phishing and is targeted at an individual or organization with personalized information. Pretexting is the act of creating an identity or a fake situation to convince the victims to reveal sensitive information, whereas baiting is based on left-infectious USBs, links, or downloads to capitalize on human curiosity. Lastly, quid pro quo attacks presuppose an offer of a service or benefit as an attempt to receive sensitive information (Adu-Manu, 2023, p. 3).

All these methods show that the attackers are thoroughly familiar with the psychology and motivation of a human being. Social engineers take advantage of fear, curiosity, and power and use them to make decisions out of emotions instead of logical judgment. It is not the technological sophistication of such attacks but the exploitation of cognitive and emotional weaknesses. Subsequently, the breach of cybersecurity is not as much a matter of technology breakdown as it is about the manipulation of behavior. The very human principle of trust, helpfulness, and

cooperation that makes social interaction stronger in the real world is applied in opposition to people in the digital world. Recognition is in itself not enough to oppose these threats. It is necessary to incorporate behavioral conditioning based on experience to make people internalize defensive responses.

This is the exposure that is offered by simulation-based exposure. Being subjected to realistic, riskless attack situations on several occasions, people start to notice the slightest details of falsehood and acquire defensive behaviors. In the long run, they come to point out signs of psychological stimuli that the attackers depend on: urgency, authority, or fear, and they react to them logically, not spontaneously. This approach is supported by experiential learning theory proposed by Kolb (1984) because humans learn in a way that is most productive in terms of their active involvement in the experience process, reflection on that experience, and the ability to transfer the lessons to a new situation. In terms of cybersecurity, this approach transforms passive knowledge into active resilience to enable users to convert knowledge into workable instincts that may be utilized in the moment.

The concept of social engineering is also important to cybersecurity education. It redefines the field as not being a matter of technical knowledge only but incorporates psychological knowledge and human-centered design. Cognitive awareness and emotional intelligence are equally important in the success of modern security systems as much as encryption algorithms or network architectures. Training using simulation thus turns into both a technical and a behavioral and educational resource as it allows people to think logically and avoid being manipulated.

By nature, the contemporary state of cybersecurity is defined by the overlap of technological progress and the susceptibility of human beings. Social engineering is this border space that takes advantage of the cognitive biases and social relationships of digital systems. Threats of this nature can only be combated in a holistic approach that involves the integration of technology, psychology, and experiential education. By achieving such a milestone as making employees active agents in the securing of digital assets instead of merely their passive participants by integrating behavioral feedback into simulated attack environments, organizations can achieve their goals of establishing a safer, more secure workplace for their employees. It is a paradigm change in the philosophy of cybersecurity to make this transition towards technology-centric protection into human-centric resilience, and it forms the basis of the simulation-based model suggested in this study.

1.2 The Human Dimension of Cybersecurity: Behaviour, Training, and Evolving Practices

The cybersecurity of the twenty-first century has been largely showing that the most vulnerable issues in digital systems are not in their code or network architecture but rather in human behaviour itself. Nevertheless, even with the advanced technologies, including firewalls, encryption, and intrusion detection systems, human factors remain the primary cause of security breaches. According to the Data Breach Investigations Report by Verizon (2023), over ninety percent of data breaches are caused because of human mistakes or psychological manipulation. Attackers have perfected the use of cognitive biases to attack in the form of urgency, authority, curiosity, and fear to make decisions and overcome technical controls. Korteling *et al*. (2023, p. 8) note that such behavioural patterns make people vulnerable to deception despite other people having minimal cybersecurity knowledge. The social-engineering attacks are based on human psychology, which is manipulated most effectively. Messages that are urgent, like those that give warnings about an account being shut down within twenty-four hours, force people to make a rush without checking the validity. Baiting tricks use the curiosity based on the fact that infected files or USB drives are left with interesting titles passed on them, like confidential. Cybercriminals use authority bias by pretending to be high authorities or individuals with authority, as they seek to accomplish this tactic to ensure compliance among junior employees (Hewage *et al*., 2021, p. 5). These instances demonstrate that effective attacks at social engineering are never really technological but psychological. Chauhan *et al*. (2024, p. 6) observe that straightforward reminder messages or awareness do not help inoculate people against such tricks. Consciousness might educate but not necessarily correct behaviour. That is why cybersecurity education should not be inert but rather an action, which enables the user to interact with the fake threats and learn by being exposed to them. Training through simulation is among the best tools in bridging the gap between awareness and behaviour. Traditionally, simulation has been a basis of professional training in aviation, medicine, and the military, where a human error in the real world could be disastrous. The implementation of comparable ideals into the framework of cybersecurity enables organizations to establish safe, regulated, and replicable spaces in which people can undergo social-engineering attacks without actual harm (Elendu *et al*., 2024, p. 3). Employees are thus able to not only acquire skills on how to identify deceptive cues, but also how to react adequately given pressure. Kavak *et*

al. (2021, p. 9) say that regular simulation drills are useful in inculcating awareness, which makes abstract information instinctive responses. As users undergo numerous simulated phishing exercises or phone-based scams, they gradually become trained to stop and ask questions and look before acting, and reduce the risk of a real-world compromise. This is one of the differences that make simulation-based training have measurable results. The measures of improvement can be determined by the data that has been received during the simulations, e.g., by the number of people who have clicked on the malicious links or how fast they have reported suspicious messages. These analytics will allow organizations to measure patterns of vulnerability, chart the behaviour change over time, and tailor additional interventions. Simulation has the ability, in this manner, to serve not just as a teaching method but as a continuous improvement evaluation framework as well. The end product of this kind of training is not to eradicate human error, which is not possible, but to instill behavioural resilience so that users can think and act instinctively when they are faced with deception. In addition to the corporate and education contexts, there has been a high level of support for simulation-based training both in the industry and in academia. In professional practice, some companies have created large-scale platforms that allow organizations to carry out phishing and social-engineering simulations for their workers. In this regard, firms like KnowBe4 and Cofense have emerged as leaders of this industry, providing cloud-based solutions to send realistic fake messages and monitor the actions of users. These services prove that simulation-based security awareness is practical, scalable, and cost-effective, benefits that can be measured in benefits that organizations of all sizes can have (Chatchalermpun & Daengsi, 2021, p. 4). Simulation has a role in academia, though less than as a means of user education, research in human-computer interaction, and artificial intelligence. Alhuzali *et al*. (2025, p. 6) established that machine-learning algorithms trained in simulated phishing conditions are more accurate at detecting deceptive content than their counterparts, which are tested only on fixed datasets. Their research indicates that experience-based learning that is dynamic, either in human beings or machines, is more adaptive and recognizes better. Furthermore, researchers like Almutairi and Alghamdi (2022, p.) argue the same. 7) Underline that simulation should not be generic but specific. The vulnerability of the users to social engineering is dependent on the job role, the level of authority, and the organizational culture. Thus, comparatively simulated based on the reflection of real communication channels and patterns of operations is likely to generate more awareness and behaviour change than regular exercises.

Such a combination of industry usage and scholarly recognition indicates that simulation is no longer an experimental idea but a main part of the contemporary cybersecurity approach. Its usefulness can be proven by industry experience, and its efficacy and flexibility are proven by scholarly research. They have transformed cybersecurity training together as an intervention that is reactive (spreading awareness) to a proactive (behavioural conditioning) system. Simulation allows the organization to predict, exercise, and reduce human vulnerabilities before the adversaries can make use of them. It is also a linkage between theory and practice as it combines the accuracy of technical expertise with psychological knowledge.

Finally, the human aspect of cybersecurity has turned out to be the determining factor in securing digital resources. Individuals are the most common points of contact for attackers, yet they can also be the best point of defence once they are sufficiently trained and empowered. Simulation-based learning is a revolutionary way of solving this dilemma, given that it brings theoretical learning into practical behavioural mastery. Simulation frameworks enhance adaptive, experiential, and human-centred security culture by integrating the perspectives of psychology, education, and computer science. Eventually, such integration becomes a paradigm shift in cybersecurity, as the focus shifts to protecting systems against outside attacks to proliferate humans as smart, robust, and active members of digital safety.

The history of the development of cybersecurity education and defence is entrenched in the convergence between psychology, learning theory, and technology. Social-engineering attacks are only made successful by not only being technologically advanced but also by applying and having knowledge of human psychology. Cialdini's (2009, p. 13) theory of persuasion, which outlines six fundamental tenets, such as authority, scarcity, reciprocity, commitment, liking, and social proof, is an excellent concept that helps to understand why people become victims of manipulation. These psychological levers are often used by the attackers to shape the decision-making. As an illustration, phishing messages posing as officials with high roles use the principle of authority, whereas the baiting techniques granting temporary access to the information that is presented as exclusive use the principle of scarcity. By manipulating people with such cognitive stimuli, human behaviour becomes a predictable exploitation tool, and it turns out that the human behaviour itself is a predictable factor of exploitation (Mollazehi *et al*., 2024, p. 4).

Simulation as a defense mechanism has a theoretical backing by Kolb's (1984, p. 22) theory of experiential learning, which states people learn best when they physically interact with experience,

meditate on their results, and generalize the results to new circumstances. Simulated attacks in cybersecurity enable the participants to experience threat conditions in the real world, but with no actual consequences. This exchange gives the learners an opportunity to link abstract information regarding social engineering to real-life experiences to build recognition and response skills. Akella (2010) goes on to suggest that experiential learning is more effective at retention of the mind and behavioural transformation than passive approaches like lecture or informational video. With repetition and feedback, the users gain intuition and confidence, and defensive behavior ceases to be a conscious effort, but becomes automatic.

The synthesis of both psychological persuasion and experiential learning theories shows that human behaviour, besides being the vulnerable part of the human being, can also be the basis of defence. Simulation-based frameworks can be effective when properly designed because they can reverse the approaches of the attacker and employ the same psychological and behavioural components of attention, repetition, and reinforcement to develop resistance instead of compliance. This two-fold application of psychology makes the field of cybersecurity not only a technical science but a behavioural science which deals with perception, thinking, and inspiration.

On the theoretical foundation of this, the simulation-based cybersecurity field has entered the period of furious innovation, which is marked by the merging of artificial intelligence, gamification, and immersive technologies. Artificial intelligence has proved useful in designing adaptive and personalised training scenarios that replicate the behaviour of an attacker in the real world. The simulation systems based on AI are able to produce phishing messages with the writing style of a particular organization, making them more difficult to detect and hence more efficient as a training tool (Mallick and Nath, 2024, p. 5). Another significant approach to enhancing involvement and motivation in cybersecurity education has been identified as gamification. Organizations can make their users engage actively and re-engage in security exercises by adding features like points, leaderboards, and rewards. Jaramillo-Mediavilla *et al*. (2024, p. 6) noted that gamified simulations are much better at knowledge retention and long-term behavioural change than traditional awareness programs.

Besides, virtual reality (VR) and augmented reality (AR) are immersive technologies that are redefining the richness and immersion of training. Budnarowski *et al*. (2025, p. 8) show that VR-based simulations are capable of simulating multidimensional environments of attacks, such as physical and social interactions, to enable users to train on complex defensive responses in almost

real environments. Such simulated experiences not only enhance preparedness, but also emotional and cognitive factors of pressure decision-making, which creates psychological preparedness. Simultaneously, there is an increasing tendency towards using simulation data as a part of more general organizational cybersecurity systems, including Security Information and Event Management (SIEM) systems. The result of this integration is that the training exercise's real-time analytics are used to inform monitoring systems and incident response procedures, forming a continuous feedback loop between learning and operational defence (Gonzalez-Granadillo *et al*., 2021, p. 10).

These developments spell out the general change of the education of cybersecurity into a smart data-driven ecosystem. Learning is personalized through artificial intelligence, interaction is maintained through gamification, and the experience is based on the environment. The synergization of these technologies represents the shift of the immobile awareness campaigns to dynamic, interactive ecosystems of lifelong learning and defence. Cybersecurity education will not only focus on increasingly sophisticated technologies but also on more intelligent human-machine cooperation, in which systems will grow with the individuals that they educate.

These promising developments notwithstanding, there are major research gaps. Despite the recognition of simulation-based training as an important defence mechanism, the majority of the current frameworks are limited to phishing training, with the rest of the equally threatening types of social engineering, pretexting, baiting, and quid pro quo (Salahdine and Kaabouch, 2019, p. 3). Also, most of the existing simulation tools are mostly awareness-driven and lack technical detection / automated defensive systems. Such fragmentation of human-based training and system-level protection restricts the effectiveness of the whole cybersecurity preparedness (Gilbert and Gilbert, 2024, p. 6).

The limitations have been recognized in academic literature, but it tends to view simulation in solitary aspects. Others are purely behavioural training, and others deal with technical detection but not with human factors. Moreover, most of the current frameworks are not flexible; they cannot adapt to new threats or novel strategies of attacks, which decreases their applicability over the long term (Elendu *et al*., 2024, p. 9). Lack of adaptable, combined systems with the potential of connecting human behaviour, machine learning, and automated defence is one significant gap in the existing research on cybersecurity.

This paper attempts to fill these gaps by providing a holistic and dynamic simulation model that unites a combination of a realistic social-engineering environment and automated detection and feedback systems. The structure will be dynamic in response to the trends of threats, which will guarantee the viability of resilience. Its twofold orientation, human awareness and system intelligence, keeps the gap between technical defence and cognitive learning. The proposed model can be characterized as a holistic approach to reactive and predictive cybersecurity preparedness through the combination of an experiential training program with an algorithmic analysis.

To sum up, the current and potential theories of simulation-based cybersecurity indicate that the success of defence is based on the interdisciplinary synthesis of psychology, education, and technology. Persuasion theory describes the susceptibility of human beings; experiential learning offers a framework for changing the behaviour; and technological innovation offers means of scalability and accuracy. However, these research gaps are persistent in nature, making it necessary to have frameworks that integrate these factors in adaptive evolving systems.

1.3 Simulation as a Strategic Tool for Cybersecurity Awareness and Defense

Simulation has become one of the most tactical methods to advance the sphere of cybersecurity awareness, test system robustness and human preparedness against the risks of social engineering. Simulation is a distinct medium of transitional between theoretical study and practical learning, in the changing digital environment where cyberattacks depend on human behavioral patterns and technological flaws less than ever before. With the simulation of real-life attack scenarios in a safe and controlled setting, individuals and organizations can be authorized to train defensive responses, comprehend decision-making patterns, and establish long-term resilience in behaviors (Korteling *et al*., 2023, p. 8). Compared to traditional types of training that involve the use of only lectures or awareness campaigns, simulation-based exercises turn the process of learning into an active, immersive experience in which the users are in an interactive setting with dynamic threat scenarios and can get a real-time response to their actions (Folorunso *et al*., 2024, p. 3).

The strategic merit of simulation is that it is able to simulate the psychological and contextual validity of cyberattacks. The urgency, trust, and curiosity the phishers, baiting, and pretexting simulations replicate are the same ones that the malicious attackers exploit. When the users are exposed to these simulated threats, they experience emotional and cognitive stimulations, which affect their decision-making. The feedback mechanism that is established within the structure at

that time highlights the areas of vulnerability and drives the right behavior by explorations and practice. This is the process that is in line with Kolb (1984, p. 22) experience learning cycle, which focuses on active participation, reflection, and adaptation as the key steps of behavioral change. Users are taken past the superficial level of awareness to the instinctive level by repetition of simulated incidents to foster digital vigilance and caution (Siddique *et al*., 2022, p. 6).

Organizational wise, simulation is more than a training mechanism, it is also used as a diagnostic and strategic planning tool. The behavioral information obtained through interaction with the users is measurable in terms of trends of vulnerability, weaknesses within the departments and progression over time. These analytics can help cybersecurity staff to draft specific interventions and optimize internal security policies. An example is that with recurrent phishing drills, departments or individuals who are demonstrated to indulge in risky behaviors can be identified, and the management can perform further coaching or system-wide limitations (Adekugbe & Ibeh, 2024, p. 8). Simulation, in that manner, turns the cybersecurity management process into a reactive approach, in which after incidents happen, to respond to the situation, and instead makes cybersecurity management a proactive model, which is based on continuous learning and behavioral intelligence (Elendu *et al*., 2024, p. 4).

Moreover, the framework of simulations supplements automated detection systems with the matter of human aspect in cybersecurity structure. Algorithms are able to track suspicious traffic or harmful attachments but human users are the first and most common contact point when dealing with social-engineering attempts. The best-built simulation ecosystem, in this regard, empowers the weakest point in security chains; the end user, through the development of awareness, confidence and the ability to discern patterns. This two-fold focus on human cognition and technological detection decreases the current gap between the security infrastructure and behavioral preparedness, resulting to a comprehensive defense stance (Kavak *et al*., 2021, p. 9).

The simulation can also be used strategically in policy development and compliance management. The current regulatory standards, including ISO 27001 and the NIST Cybersecurity Framework, underline the continuous training and risk evaluation as the core of the organizational resilience. Simulation meets both criteria because it offers practical data on user proficiency and it can be utilized to test incident-response processes periodically without compromising actual systems (Hewage *et al*., 2021, p. 5). Frequent simulation training also makes cybersecurity awareness not a transient event but a permanent institution, which makes the workforce practice consistent with

the regulatory and ethical requirements. Low-cost web-based simulations can democratize access to cybersecurity training in educational organizations or those in the public sector where the resources are usually scarce, and resilience against any type of attack can become achievable (Chatchalermpun and Daengsi, 2021, p. 4).

The other strategic strength of simulation is that it is flexible to new technologies. Simulations built on artificial-intelligence have the potential to produce real phishing messages, adaptive scenarios, and customized learning trajectories, given the user history. Elements of gamification can be integrated into it like performance scores, progress dashboards or achievement badges to enhance engagement and incentive. Gamified cybersecurity training improves knowledge retention and creates the culture of an ongoing improvement, as Jaramillo-Mediavilla *et al*. (2024, p. 6) note. Once simulation is interactive and rewarding, it stops being a mandatory compliance and will instead be a self-directed learning where employees will internalize safe digital habits without being forced to do so.

Nevertheless, the implementation of simulation frameworks should also take ethical and psychological considerations. Because simulated attacks are by definition a form of deception, developers should respect the principles of informed consent, data privacy, and emotional safety. Debriefing of the participants must always follow exercises to explain the learning purpose and strengthen the confidence between the staff and the management. Ethical design guarantees that the process of simulation is a positive experience instead of a punitive one (Almutairi and Alghamdi, 2022, p. 7). It turns errors into the possibility to learn and improve the confidence of users in their skills to act in response to actual threats.

Simulation is a convergence of technology, psychology and pedagogy in terms of strategy. Its comprehensive outlook recognizes that cybersecurity is not just a process of stopping an intrusion, but developing a resilient mentality that intelligently sees, considers and reacts to threats. Abstract cybersecurity policies are transformed into lived experiences through the incorporation of behavioral analytics, real-time feedback, and adaptive content into the simulation frameworks. Simulation-based systems provide a long-lasting way of approaching continual learning, quantifiable advancement, and long-term defense preparedness as organizations seek to be resilient in an ever-changing cyber environment (Adu-Manu, 2023, p. 3).

Thus, this highlights the fact that simulation is not a mere technical breakthrough but a strategic doctrine one which considers human consciousness as the living defense mechanism. By

integrating experience into the cybersecurity practice, organizations will be able to transform vulnerability into vigilance and training into a empowering cycle. Overall, the frameworks of simulation-based defense teach users not just to become familiar with the practice of detecting deception but also to think, act, and reason with confidence and engage in collective effort to enhance the digital safety of their institutions (Mallick and Nath, 2024, p. 5).

CHAPTER TWO: PROJECT SCOPE, TECHNOLOGIES, AND METHODOLOGICAL FOUNDATIONS

2.1 Foundations and Scope of the Simulation-Based Cybersecurity Framework

This chapter establishes the practical, technological, and methodological foundations of the proposed simulation-based cybersecurity framework. While Chapter One examined the theoretical background of social engineering and human vulnerability, the focus here shifts toward the concrete design decisions, system boundaries, and implementation logic that guide the development of the framework. The chapter defines the scope of the project, outlines the selected technologies, and explains the methodological rationale underpinning the framework's construction and evaluation.

The primary objective of the framework is to provide a controlled, web-based simulation environment capable of reproducing common social engineering attacks, including phishing, spear-phishing, baiting, and pretexting. Within this environment, users interact with simulated attacks that closely resemble real-world digital communication scenarios, such as emails, login pages, and online forms, without exposing real systems or data to risk. User interactions are monitored, analysed, and immediately followed by contextual feedback that explains deceptive elements and appropriate defensive responses. This approach aligns with experiential learning principles, where learning occurs through direct experience, reflection, and behavioural adjustment (Kolb, 1984).

The scope of the project is intentionally limited to human-centric cyberattacks rather than encompassing the full spectrum of technical threats such as malware propagation or distributed denial-of-service attacks. This restriction enables focused analysis of psychological manipulation, behavioural bias, and user decision-making, which are central to social engineering success. Industry evidence indicates that social engineering remains a dominant factor in successful breaches, justifying the framework's narrow but deep focus on these attack types (Verizon, 2023). By concentrating on behavioural vulnerabilities, the framework enables systematic observation of how users perceive, interpret, and respond to deceptive stimuli.

Technological accessibility and scalability are guiding principles of the framework's design. The system is developed using lightweight, open-source web technologies, including HTML5, CSS3, JavaScript, and Node.js. These technologies were selected to ensure cross-platform compatibility,

low deployment overhead, and ease of integration within diverse organizational environments. A web-based architecture allows the framework to operate on both desktop and mobile devices, reflecting contemporary patterns of digital communication and user interaction.

Methodologically, the framework adopts a hybrid analytical–empirical approach. Analytical design methods guide the specification of system architecture, attack models, and detection logic, while empirical testing evaluates user behaviour, detection accuracy, and response time under simulated conditions. This dual approach ensures that the framework is both technically sound and empirically validated. Iterative refinement based on experimental results supports continuous improvement of system performance and user learning outcomes.

A defining feature of the framework is its treatment of users as active participants in cybersecurity defence rather than passive sources of error. The system is designed to promote engagement through interaction, immediate feedback, and repeated exposure to simulated threats. When users make risky decisions, the framework provides real-time explanations of the underlying deception techniques, reinforcing learning through direct experience. This user-centred approach transforms simulation into a cognitive learning process rather than a purely technical exercise.

The framework is developed using agile and modular design principles. Core components are implemented, tested, and refined incrementally, allowing functionality to be validated before expansion. This modularity supports future extensions, including additional attack vectors, enhanced detection mechanisms, and integration with organizational security systems. By constraining initial scope while maintaining extensibility, the framework remains feasible, adaptable, and aligned with evolving cybersecurity challenges.

In summary, this section defines the conceptual boundaries, technological foundation, and design philosophy of the proposed framework. By integrating behavioural theory, accessible technology, and experiential learning mechanisms, the framework demonstrates how theoretical insights into social engineering can be translated into a practical and scalable cybersecurity solution.

2.2 System Architecture and Technological Infrastructure of the Simulation Framework

The proposed simulation-based cybersecurity framework is structured as a modular, multi-layered system designed to simulate social engineering attacks, monitor user behaviour, and deliver

adaptive feedback. Each component performs a specific function, while their integration enables a continuous cycle of simulation, detection, feedback, and analysis.

At the user-facing level, the simulation interface serves as the primary point of interaction. Developed using HTML5, CSS3, and JavaScript, this interface replicates common digital environments such as email clients, authentication pages, and web forms. Visual and functional realism is prioritised to encourage natural user responses that reflect real-world behaviour. High-fidelity simulation is essential for behavioural authenticity, as users are more likely to respond realistically when interfaces resemble familiar digital contexts (Ekpobimi et al., 2024).

User interactions within the simulation are processed by the detection engine, which operates as the analytical core of the framework. This component monitors behavioural indicators such as link interaction, credential submission attempts, and reporting actions. All events are logged and analysed to identify risky behaviour patterns and vulnerability trends. By transforming each simulation into a behavioural experiment, the detection engine enables systematic data collection for both training and evaluation purposes (Hess & Graffi, 2025).

The defensive response module provides real-time feedback following user interaction with simulated threats. When a risky action is detected, the system generates contextual explanations outlining the deceptive cues involved and appropriate mitigation strategies. Immediate feedback reinforces learning by linking action and consequence, consistent with experiential learning theory (Kolb, 1984). This mechanism ensures that errors contribute directly to knowledge acquisition rather than remaining unexamined.

Behavioural data generated by simulations are aggregated and visualised through the analytics dashboard. This component presents metrics such as click-through rates, reporting frequency, and reaction time, enabling administrators to assess user performance and track improvement across simulation cycles. The dashboard supports evidence-based decision-making by identifying high-risk behaviours and evaluating the effectiveness of training interventions (Adekugbe & Ibeh, 2024).

The back-end infrastructure is implemented using Node.js and Express.js to support asynchronous, event-driven processing. This architecture ensures real-time responsiveness during concurrent simulations and enables scalable deployment across organizational environments. Data storage is supported through flexible database options, including relational and document-oriented systems, allowing the framework to accommodate structured metrics and unstructured behavioural logs.

Analytical processing is enhanced through integration with Python-based data analysis libraries such as Pandas and Matplotlib. These tools support trend analysis and visualization of behavioural changes over time, extending the framework's utility beyond training to behavioural research and evaluation.

Security and ethical safeguards are embedded throughout the system architecture. Simulations operate within isolated environments to prevent unintended interaction with real systems, while data transmission and storage are protected using standard encryption protocols. These measures ensure that realism does not compromise system integrity or user privacy.

Interoperability is achieved through RESTful APIs, allowing integration with external systems such as Security Information and Event Management platforms and Learning Management Systems. This capability enables simulation results to inform broader organizational security processes and supports adaptive training workflows.

Overall, the architectural design balances realism, scalability, and ethical responsibility. Through modular integration of simulation, detection, feedback, and analytics, the framework functions as both a training tool and a behavioural analysis system capable of evolving alongside emerging threats.

2.3 Methodological Approach and Practical Applicability

The study adopts an analytical–empirical methodological approach grounded in simulation modelling, experimental evaluation, comparative analysis, and the Design Science Research (DSR) paradigm. This combination ensures that the framework is developed systematically and evaluated rigorously within realistic yet controlled conditions.

Simulation modelling serves as the primary research method, enabling the recreation of social engineering attacks without exposing participants or systems to actual risk. Controlled simulations allow observation of user behaviour under realistic conditions while maintaining experimental safety and repeatability (Kavak et al., 2021). Through simulation, diverse attack patterns can be modelled and tested consistently across participants.

Experimental evaluation complements simulation by measuring user responses using quantitative metrics such as detection accuracy, reporting rate, and reaction time. These metrics provide objective indicators of behavioural change and defensive capability. Controlled testing

environments allow isolation of relevant variables and reduce external interference, strengthening the validity of the results (Elendu et al., 2024).

Comparative analysis is employed to assess the performance of the proposed framework relative to traditional cybersecurity awareness approaches. Unlike static training materials or isolated detection systems, the framework integrates simulation, feedback, and behavioural measurement. This comparison highlights improvements in adaptability, engagement, and user preparedness.

The Design Science Research paradigm provides the overarching methodological structure. Within this framework, the system is treated as a knowledge-generating artefact that addresses a real-world problem while contributing to academic understanding. Iterative cycles of design, evaluation, and refinement enable continuous improvement and responsiveness to evolving threat models.

A mixed-methods strategy is incorporated to capture both measurable performance outcomes and underlying cognitive processes. Quantitative data reveal behavioural trends, while qualitative insights from post-simulation reflections provide context for user decision-making. This triangulation enhances analytical depth and strengthens the interpretive validity of the findings.

Ethical considerations are addressed through informed consent, anonymity, and post-simulation debriefing. Participants are informed of the simulated nature of the attacks and the educational intent of the study, ensuring that deception serves a pedagogical rather than manipulative purpose.

The practical applicability of the framework is reinforced by its modular design and compatibility with existing organizational security infrastructures. Unlike narrowly focused phishing simulators, the framework supports multiple attack vectors and integrates behavioural data into broader defence strategies (Chatchalermpun & Daengsi, 2021). Its adaptability ensures relevance across evolving cybersecurity environments (Gonzalez-Granadillo et al., 2021).

In summary, the methodological approach ensures that the framework is both empirically grounded and practically relevant. By combining simulation, experimentation, comparative evaluation, and iterative design, the study produces a robust and adaptable solution that advances understanding of human-centred cybersecurity defence.

CHAPTER THREE: END-USER CHARACTERISTICS, EXPECTATIONS, AND COST ANALYSIS

3.1 End-User-Centered Orientation and Practical Foundations for Framework Deployment

Effective deployment of a simulation-based cybersecurity framework requires a clear understanding of the characteristics, behaviours, and constraints of its intended end-users. Regardless of the strength of technical security controls, human interaction remains a decisive factor in the success or failure of cybersecurity defences. This section examines the behavioural, cognitive, and organizational attributes of users who interact with the framework and outlines the practical considerations required to ensure sustainable and effective deployment.

The framework is designed for heterogeneous user groups, including administrative, operational, managerial, and technical staff within an organization. These groups differ significantly in digital literacy, exposure to cybersecurity concepts, and familiarity with threat indicators. Technical personnel may possess baseline knowledge of phishing cues and anomalous system behaviour, while non-technical users often rely on trust-based assumptions in internal communication. This disparity increases vulnerability to manipulation techniques that exploit urgency, authority, or emotional pressure.

User diversity also extends to demographic and role-based factors that influence interaction with digital systems. Less experienced users may respond impulsively to unfamiliar interfaces, while senior staff may be targeted through authority-based pretexting due to their access privileges. These variations necessitate adaptive simulation scenarios rather than uniform training content. The framework therefore incorporates configurable attack patterns and difficulty levels to reflect differing user profiles and exposure risks.

Cognitive biases play a central role in social engineering success. Biases such as urgency bias, authority bias, and fear of non-compliance frequently override rational verification processes. By embedding these psychological triggers within controlled simulations, the framework reproduces realistic decision-making conditions and enables observation of authentic user behaviour. This approach supports meaningful behavioural assessment rather than theoretical knowledge testing.

The framework adopts a learning-oriented rather than punitive approach to cybersecurity training. User errors are treated as data points for reflection and improvement rather than indicators of negligence. Through experiential exposure and immediate feedback, users are encouraged to recognise vulnerabilities and adapt their behaviour over time. This design philosophy aligns cybersecurity education with adult learning principles and behavioural adaptation, emphasising awareness and resilience rather than enforcement.

From a deployment perspective, the framework is designed to be cross-departmental, scalable, and resource-efficient. Infrastructure requirements, data handling practices, and system maintenance are evaluated against typical organizational budgets and technical capacity. The framework's value proposition is based on its ability to reduce behavioural risk, demonstrate measurable improvement, and integrate smoothly into existing security practices.

Sustainability is further supported through modular system architecture. New attack scenarios, updated reporting features, and integrations with organizational security tools can be added incrementally without restructuring the entire system. This adaptability ensures continued relevance as threat landscapes and organizational needs evolve.

In summary, the framework prioritises human-centred design as the foundation for effective cybersecurity training. By accounting for behavioural diversity, cognitive bias, and organizational feasibility, the system is positioned not only as a functional tool but as a scalable and sustainable component of cybersecurity practice.

3.2 User Expectation

End-users expect the cybersecurity simulation framework to be intuitive, responsive, and minimally disruptive to routine work activities. Ease of use is a critical determinant of engagement, as users are more likely to participate meaningfully when interfaces resemble familiar digital platforms such as email systems and web applications. A simple and recognisable interface reduces cognitive load and supports natural interaction with simulated threats.

Realism is another key expectation. Simulation scenarios must closely reflect real workplace communication patterns and threat vectors in order to maintain credibility. Unrealistic or exaggerated scenarios risk disengagement and reduce the transferability of learned behaviours to real-world situations. High-fidelity simulation encourages users to apply the same judgement processes they would use during actual cyber incidents.

Users also expect immediate and constructive feedback following interaction with simulated threats. Rather than merely indicating incorrect actions, the framework provides contextual explanations that identify missed warning signs and suggest alternative responses. This feedback supports reflective learning and helps users understand their behavioural tendencies without inducing fear or blame.

From an organizational perspective, stakeholders such as IT managers and security teams expect aggregated insights into behavioural trends rather than individual surveillance. Metrics related to reporting behaviour, response time, and engagement levels are intended to inform training strategies and risk mitigation decisions at departmental or organizational levels. This approach reinforces trust while enabling evidence-based intervention.

Scalability and adaptability are shared expectations between users and organizations. As social engineering techniques evolve, the framework must support updates to scenarios and training content without extensive redevelopment. This flexibility ensures long-term relevance and cost-effectiveness, allowing the system to adapt alongside changing threat environments.

Effective alignment between user and organizational expectations requires a balanced design approach. Training must be relevant, respectful of user experience, and demonstrably valuable. Systems perceived as overly simplistic, intrusive, or punitive risk disengagement, whereas those that support learning and relevance foster sustained participation.

Overall, user expectations highlight the importance of realism, usability, transparency, and adaptability. Meeting these expectations enables the framework to function as a credible and trusted tool for cybersecurity awareness rather than a compliance-driven exercise.

3.3 Cost Analysis and Justification

The development and deployment of the proposed cybersecurity simulation framework involve several interrelated cost components associated with technical implementation, content development, and operational coordination. These costs represent a strategic investment in reducing behavioural vulnerabilities rather than a one-time technical expenditure.

The primary cost component is software development, encompassing front-end and back-end implementation as well as user interface design. Creating a realistic and responsive simulation environment requires structured coding, secure architecture, and usability-focused design. This component is estimated at $3,000, reflecting standard development and UX design costs.

Testing infrastructure represents another significant cost. The framework requires hosting services, browser compatibility testing, and simulation tools capable of replicating social engineering scenarios consistently. These resources ensure reliability and realism during pilot and deployment phases. The estimated cost for testing infrastructure is $1,500.

Personnel costs include the involvement of a software developer and a cybersecurity consultant. Development expertise ensures functional implementation, while cybersecurity expertise ensures that simulated threats reflect current attack patterns. Combined personnel costs are estimated at $2,500.

Training material development supports the educational effectiveness of the framework. This includes explanatory feedback messages, awareness modules, and guidance content aimed at reinforcing behavioural change. The estimated cost for content development is $800.

Administrative overhead covers project coordination, documentation, stakeholder communication, and version control. These functions support transparency and systematic project execution and are estimated at $700.

Table 3.1: Estimated Cost

Expense Category	**Description**	**Estimated Cost (USD)**
Software Development	Front-end and back-end coding, UI/UX design	$3,000
Testing Infrastructure	Hosting, browsers, and simulation tools	$1,500
Personnel	Developer and cybersecurity consultant fees	$2,500
Training Materials	Awareness content, feedback modules	$800
Administrative Overhead	Project coordination, documentation	$700

Total Estimated Cost		**$8,500**

The justification for this investment is grounded in preventive risk mitigation. Social engineering remains a dominant cause of security incidents, with human error accounting for a substantial proportion of data breaches (Verizon, 2023). Preventive training reduces the likelihood of successful attacks and limits associated recovery costs, reputational damage, and operational disruption.

Even modest behavioural improvements can yield significant financial benefits. Avoidance of a single successful phishing incident may offset the entire cost of framework deployment. Additionally, the modular and scalable design ensures that future updates can be implemented at minimal additional expense, extending the framework's operational lifespan.

Beyond financial considerations, the framework supports informed decision-making through behavioural analytics and progress tracking. Organizations gain visibility into risk trends and training effectiveness, enabling targeted interventions and continuous improvement.

In summary, the cost analysis demonstrates that the proposed framework represents a justified and sustainable investment. By combining realistic simulation, behavioural insight, and scalable design, the system offers long-term value through reduced vulnerability, improved awareness, and strengthened organizational resilience.

CHAPTER FOUR: PROJECT DOCUMENTATION AND DESIGN

4.1 System Architecture and Simulation Workflow

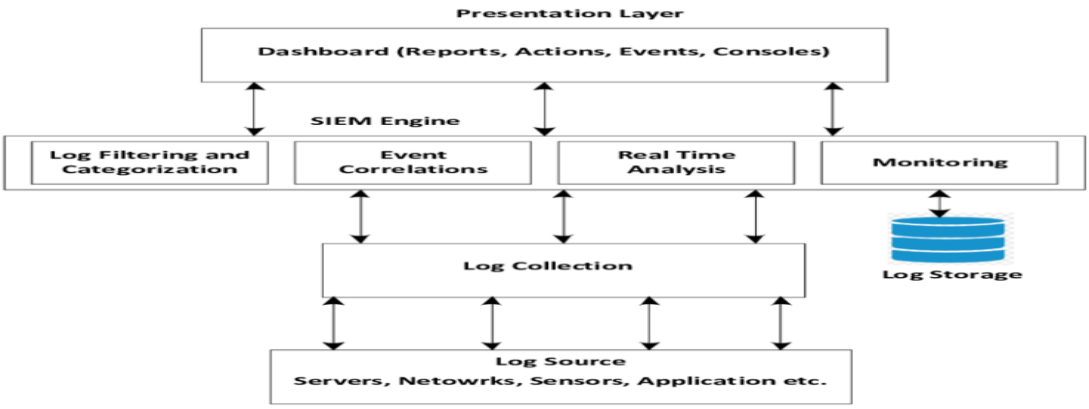

Figure 4.1: The System Architecture diagram for a visual summary

The integrated system architecture and the simulation workflow together form the operational backbone of the cybersecurity training framework. It is designed as a modular web-based structure able to simulate realistic social engineering attacks, detect risky user actions, and immediately provide feedback for awareness reinforcement and behavioral change. This architecture consists of four major layers: Presentation Layer, Application Layer, Data Layer, and Security Layer, each responsible for enabling smooth interaction between the user and the system.

The Presentation Layer serves as the user-facing front-end interface. It is developed using HTML5, CSS3, and JavaScript to present simulated attack scenarios in forms that resemble real-world communication systems such as email clients, web portals, and digital message prompts. In such a way, it is similar to familiar work-related communication environments where the user has the opportunity to respond authentically, reflecting real behavioural patterns and decisions.

Beneath this is the Application Layer, developed on Node.js. The application processes user activities in real-time, acting as a bridge between user interaction with the system and the underlying logic. It interprets user inputs and assesses behavior to trigger detection mechanisms. Every time a user clicks on a suspicious link, enters their credentials into a spoofed website, or attempts to open a disguised USB file, this layer triggers a response in the feedback engine in real time.

The Data Layer logs all interactions, performance outcomes, and training progress. It uses MySQL or SQLite, depending on the scale of deployment. This data underpins the performance analytics, enabling identification by organisations of common vulnerabilities, users who require extra training, and improvement trends in user behavior.

The Security Layer assures that all simulations remain safely contained and can't cause actual harm. It manages authentication, enforces standards of data protection, and ensures the sandboxing of operations to ensure no simulated threat operates outside controlled boundaries. This layer also protects user privacy and organisational data integrity.

These layers together represent a functional ecosystem where human interaction, system logic, and security assurance balance each other. In designing and organizing these layers, it was emphasized that system architecture is not purely technical structuring but aligning technology with human needs, memory, behavior patterns, trust, and responsibility. Quite clearly, a well-designed architecture had to be adaptive, anticipatory, and ethical. Structure is not a limitation--it's preparation for growth, change, and resilience.

The simulation workflow describes how the user will interact with the training environment. After logging into the system, the user is exposed to a randomly chosen simulation scenario. The scenarios simulate real-world cyber threats in the form of a phishing message, a spoofed login portal, a baiting link, or infected storage devices. Such situations are similar to practical work conditions, so that the response of the user is realistic instead of theoretical.

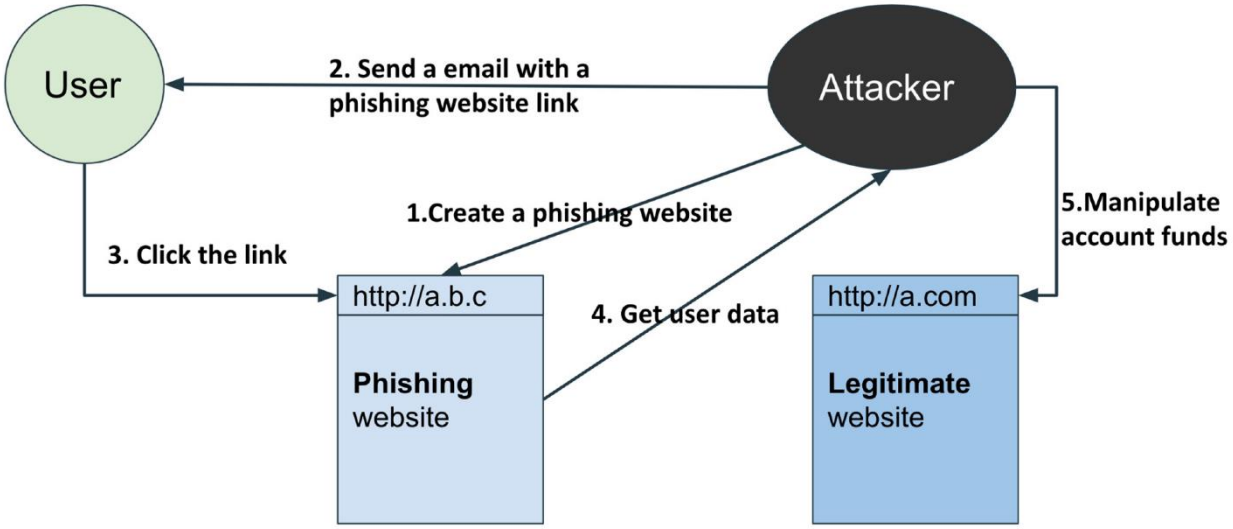

Figure 4.2: Phishing Attack Workflow Diagram

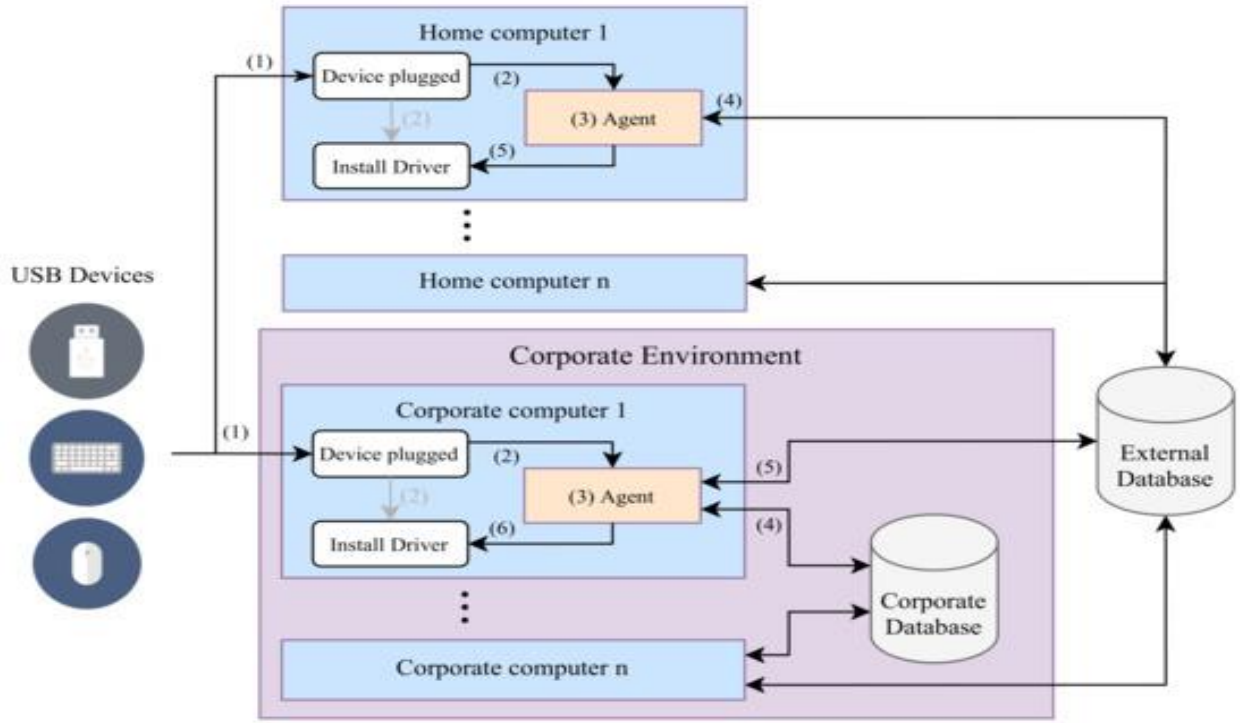

Figure 4.3: USB Attack Workflow Diagram

The Detection Engine assesses an action as the user reacts by clicking, entering credentials, ignoring, or reporting-and instantaneously classifies it as safe or risky. On detecting risk, the Feedback Module immediately notifies the user about the various threat indicators they missed and how to react differently in similar situations in the near future.

Two main showcase cases demonstrate how the workflow works in practice. In a simulated phishing email, the user interacts with a deceptive email; in case of detection of unsafe behavior, a real-time warning message pops up, as demonstrated in Figure 4.2. In USB baiting, interaction with a simulated device is tracked and recorded, followed by corrective feedback. Such simulations enhance both digital and physical threat awareness through these different approaches, as demonstrated in Figure 4.3.

This workflow in design emphasized the thought that learning is not linear, but rather cyclical. Understanding evolves via experiences, corrections, and reflections. Immediate feedback turns errors into lessons from failures. It established the truth that mistakes are evidence of engagement and thinkers at work, not indications of weaknesses. The workflow, hence, does more than teach cybersecurity: it supports psychological growth, resilience, and awareness. It also highlighted the need for flexibility: users learn differently, respond differently, and process risk differently.

Allowing the simulation to adapt to pace and behavior means designing with empathy, understanding that diversity in cognitive patterns, confidence, age, digital familiarity, and emotional responses is real. Every click is not only a technical action but also curiosity, hesitation, caution, or confidence expressed in digital form. The combined system architecture and workflow are more than just a training platform. It is, in fact, representative of the relationship of technology and humanity, structure and emotion, logic and fear, caution and courage. The system does not build cybersecurity competencies exclusively but fosters awareness, reflection, and mindful digital behavior.

4.2 Use Case Analysis and Interaction Design

To balance the conceptual description of the proposed framework to clearly defined and engineerable system, it is essential that the interaction of the various actors with the system and how system functionality is achieved in actual operation conditions are explicitly stated. Although the above sections of this chapter presented the overall architecture and the general workflow of the simulation-based cybersecurity framework, they did it at a high level of abstraction. This subsection thus fits into the architectural overview, and offers an in-depth use case analysis and interaction design, which combine to explain system behaviour, functional boundary, and execution logic.

The use case analysis will be well suited in this case since the framework will have several actors, different system responsibilities, and dynamic interactions, which evolve with time. Through the formal specification of use cases, the intended behaviour of the system is no longer implied by narrative specifications but rather made explicit, verifiable and traceable to the system requirements as previously identified in the earlier parts of this chapter and the implementation decisions, as we will discuss later on in this chapter.

4.2.1 System Actors and Roles

The suggested framework presupposes three main types of actors, each of which interacts with the system in a specific way and with various goals. The initial performer is the administrator, who is usually a representative of a security officer or training manager, who is required to set up the simulations, track results, and assess organisational vulnerability to social engineering attacks. The administrator communicates with the system by using management interfaces with which they can control situations, groups of users and evaluation parameters.

The second participant is the end user, who in this case is an employee or a system participant, who in the training and evaluation process is exposed to simulated social engineering attacks. The end users do not have to have any technical knowledge, but rather can interact with the system via interfaces that are designed to intuitively mimic the real-life communication mediums, i.e. email messages or web-based e-mail log in forms. The behavioural data on which the system operates its detection and evaluation logic are their actions.

The third participant is the system itself, and it includes the automated elements of delivering the scenarios, behaviour monitoring, risk evaluation, feedback generation, and data analysis. Though it is not a human actor but the system is an active component of decision-making process and as such, it should be considered an explicit participant in the interaction modelling.

4.2.2 Fundamental Applications of the Framework

The scope of the framework operation is specified by a complex of the key use cases which describe the process of the framework supporting simulation-based cybersecurity awareness and evaluation. These application scenarios are not isolated but logically related, and they constitute a logical flow of interrelated interaction that cuts across configuration, execution, analysis, and feedback.

Simulation scenario configuration is one of the key applications of the system. Within this use case, the administrator establishes the attributes of a social engineering attack scenario, which comprise of the attack vector, difficulty level, delivery channel and evaluation parameters. The stage of configuration is an important one, as it defines the level of realism and the value of the simulation as a pedagogical activity. The system checks the input of an administrator, stores the definition of a scenario and gets ready to be executed in a controlled environment.

After achieving the definition of scenarios, an administrator starts a simulation session. In this use case, the system will choose the right user group, implement the configured scenario and monitor the execution context. It is the simulation engine that will provide the simulated attack in a way that is close as possible to the real-world situation, but that does not intersect with the real organisational systems.

Another major application is whereby an end user is sent and communicates with the simulated attack. The user can either dismiss the message, follow a link, provide credentials or report on the suspicious material. The system captures these actions in real time and they are used to base the future analysis of behaviours. Notably, the system does not dictate the decision-making process in

the user in this step since the task is to monitor genuine responses and not to predetermine behaviour.

After interacting with the users, the system will automatically make detection and assess risk. Here, the detection engine would evaluate the behaviour observed against established rules and thresholds to categorise behaviours as being safe, risky or critical. This is a transparent and constant classification process, which means that the results of evaluation can be justified and replicated.

The other critical use scenario is feedback and training explainations. Once the simulation is complete or the decisive action has been taken, the system gives a contextical feedback to the user. This feedback is what makes a given action deemed as risky or safe and what signs could have been identified to detect the simulated attack. This application case fills the gap between assessment and learning, which supports the learning purpose of the framework.

Lastly, the system assists in aggregation and reporting of results. Behavioural data gathered throughout the simulation processes is processed, and it is displayed to the administrator in reports and dashboards in this use case. These outputs facilitate longitudinal study of the user behaviour, detection of high-risk patterns and determine the effectiveness of the training the longer the time.

Figure 4.4 of the use case diagram describes these interactions in a UML representation offering an overview of the association between system actors and the core functional capabilities of the framework.

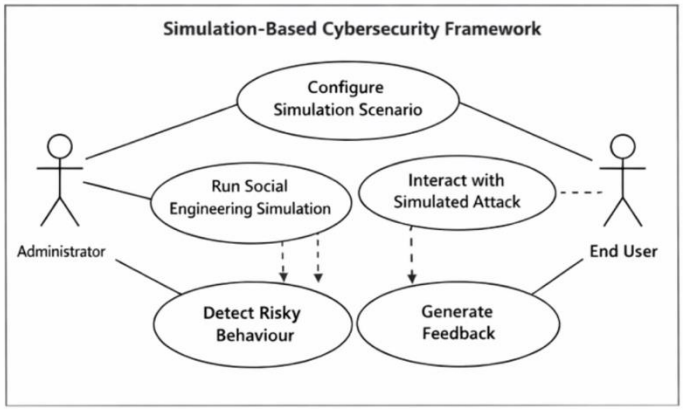

Figure 4.4: Use Case Diagram of the Simulation-Based Cybersecurity Framework

4.2.3 Interaction Flow and Sequence Design

While use cases define what the system does, interaction and sequence modelling explain how system components and actors collaborate over time to realise each use case. To this end, sequence diagrams are used to represent the temporal order of interactions during key operational scenarios. A representative interaction scenario is the execution of a phishing simulation. The sequence begins when the administrator initiates a simulation session through the management interface. This request is processed by the system, which retrieves the relevant scenario configuration and user list. The simulation engine then delivers the phishing content to the selected end users.

Upon receiving the simulated message, the end user performs an action, such as clicking a link or reporting the message. This action triggers an event that is captured by the data collection component and forwarded to the detection engine. The detection engine evaluates the action in accordance with predefined rules and assigns a corresponding risk classification.

Once evaluation is complete, the feedback module generates a response tailored to the user's action. This response is delivered through the user interface, providing immediate explanatory feedback. Simultaneously, the evaluated data is persisted in the system's data store and forwarded to the analytics module for aggregation and reporting.

This interaction sequence demonstrates how the system integrates simulation delivery, behavioural monitoring, decision logic, and feedback generation into a cohesive operational flow. A UML sequence diagram illustrating this process is presented in Figure 4.5 and serves as a concrete reference for both system design and implementation.

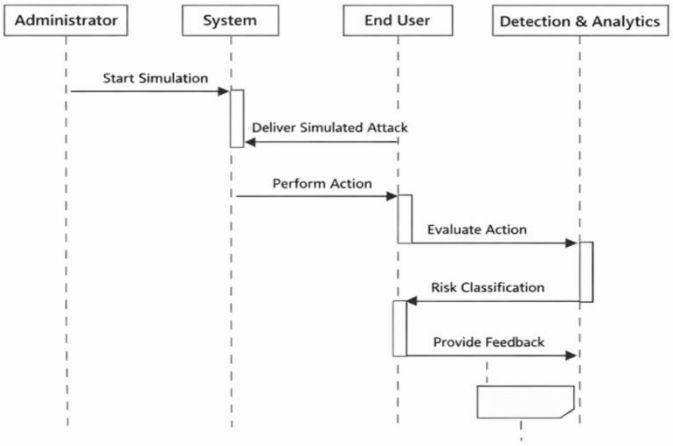

Figure 4.5: Sequence Diagram for Phishing Simulation Scenario

4.2.4 Role of Use Case Modelling in System Design

Inclusion of formal use case and interaction modelling has various uses in this thesis. First, it removes confusion through the explicit description of system behaviour, thus overcoming the fear of a reader having to deduce the functionality by reading descriptions. Second, it offers a definitive connection between system requirements and implementation, and therefore, traceability between design phases. Third, it provides a basis of following parts of this chapter, especially those dealing with component architecture, interface design, and details of implementation.

The proposed framework, based on the system design grounded on the clearly defined use cases and interaction flows, takes the system design out of the realm of the conceptual explanation and attains a degree of technical specificity that can be considered the master-level system-oriented thesis.

4.3 Data Model and Database Schema

The simulation-based framework of cybersecurity which is supposed to monitor, review, and optimize user behaviour cannot work efficiently without a clear data persistence layer. The system proposed is based on a systematised gathering, storage and examination of heterogeneous data produced during the life cycle of simulation sessions, such as configuration information, user interaction occurrences, behavioural category and aggregate performance indicators. This is the reason why a well defined data model is needed in order to assure data consistency, traceability and analytical soundness.

In this sub section, the logical data model of the framework is thus unveiled and how the various data entities are interrelated with each other is explained. Taking the database schema explicitly, the system design breaks the abstract architectural view into a concrete and engineerable specification, all of which allows implementation, evaluation and the extensibility of the future.

4.3.1 Data Persistence Requirements and Modelling Approach

The model creates data at various points of operation. Configuration data of simulation scenarios and participant groups need to be persistently stored before execution to allow simulations to be repeated, compared and adjusted with time. In the process of execution, both user activities and

system reactions are created dynamically and have to be logged using adequate time resolution so as to be capable of conducting precise behavioural analysis. Once it is executed, derived metrics and aggregate outcomes are to be stored to aid reporting, longitudinal analysis, and effectiveness of training.

In addressing these needs, the system takes a structured data model where the configuration data, operational event data, and analytical results are well separated. Relational data model is highly appropriate in this situation because it facilitates a clear statement of the relationship among users, scenarios, simulation sessions and actions logged, and also provides an efficient querying and aggregation. However, the logical model discussed in this section is abstract enough to implement it with the help of either a relational database management system or a document-oriented store, depending on the deployment requirements.

4.3.2 Data Core Data Entities and Relationships

The core of the data model is the User entity, which is the representation of participants that are involved in the simulation framework. The users are uniquely identified and each of them is tied to the contextual attributes like role, department or training group. These properties allow splitting up the results and comparison between them across organisational units without revealing any sensitive personal identifiers.

A special Scenario entity depicts simulation scenarios. Each case determines the nature of a specific social engineering attack such as attack vehicle, level of difficulty, and metadata description. Simulation sessions are instantiated not through scenarios, but by using them as templates.

Simulation Session entity is used to capture the execution of a scenario. The simulation session is a real-life example where a particular situation is implemented on a particular group of consumers under a certain time. This disconnection between scenarios and sessions enables a scenario to be reused by a series of experiments, making it easier to compare and evaluate scenarios controlled.

The User Action entity captures user interactions present during a simulation session. Every action undertaken is also related to a particular behavioural event, including clicking a link, inputting credentials, disregarding a message, or reporting suspicious content. Actions are not only stamped with the time of their occurrence but also they are associated with the user executing the action as well as the session of the simulation during which action took place. This design allows the timelines of interactions to be reconstructed on a fine-grained scale and allows calculating the metrics of response time.

Lastly, the Metrics entity symbolizes aggregated analytical results. The metrics are based on sets of user actions and generalise behavioural performance on a level of a simulation session, user group, or organisational unit. These are a click-through rate, reporting rate and average reaction time. The system keeps a strong line between observed behaviour and analytical interpretation by keeping metrics and raw interaction data apart.

These associations among them are shown in the Entity Relationship Diagram Figure 4.6. As this diagram demonstrates, one single scenario can result in a number of simulations, during which a single simulation can have several users and users can produce numerous action records in one simulation. Simulation sessions are linked to metrics, which can also be further aggregated by users or departments.

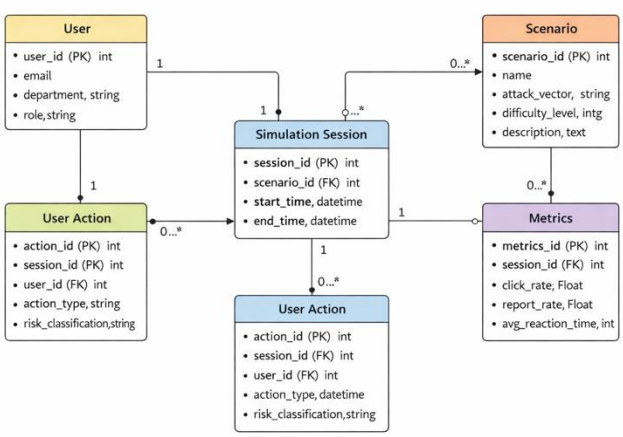

Figure 4.6: Entity Relationship Diagram of the Simulation-Based Cybersecurity Framework

4.3.3 Description of the Database Schema

In the implementation perspective, the above logical entities would be converted to a collection of database tables or collections having well defined keys and relationships. The user records have a distinct primary key, which is accessed by user action records, and thus referential integrity exists

between behavioural events and the users who cause them. The records of scenarios also have a primary key that associates scenario records to the simulation sessions, and thus they can be traced back to scenario configuration.

Records in simulation session will have foreign keys to the corresponding scenario and time limits to the execution time. This framework enables the system to differentiate overlapping or repeated simulations as well as analyse the trend in behaviour over time. The records of user actions contain foreign keys to the user and the simulation session and the material of the action such as the type of the action, the time of the action, and the risk classification given to the user.

Metrics captures the simulation session that they are matched to and accumulates the calculated values that summarise behavioural performance. The design has the effect that the results of analysis can be regenerated or re-calculated in case evaluation logic is changed and, also, enabling precomputed indicators to be efficiently retrieved to support reporting needs.

The schema provides logical consistency to the data model by explicitly defining primary and foreign key relationships, and facilitates the effective querying of the data model both in operation and after the fact.

4.3.4 Role of the Data Model in System Evaluation and Extensibility

The data model in this section is extremely important in the implementation of the system as well as in its evaluation and expandability. Since behavioural data is stored at a granular level and is connected in a systematic fashion across entities, the framework can support longitudinal studies that investigate the change in user susceptibility during repeated simulation cycles. Moreover the schema has a modular design, which means that other entities like new types of attacks or more sophisticated behavioural indicators can be added without necessarily having to redesign the schema.

The framework meets the need of concrete engineering documentation by basing the system design on a well-defined data model and database schema and allows the implementation, testing, and experimental evaluation discussed in later chapters of this chapter to have a sound base.

4.4 Component and Module Architecture

The data model is what determines how the information is organized and stored in the system, but the architecture of the components and modules must be clearly defined to describe how the functioning of the system is distributed, coordinated, and performed in the system. This subsection

thus gives a component level perspective of the proposed simulation based cybersecurity framework in terms of the roles of the individual modules and how they relate with each other. In this way, the system design is described beyond the high-level layered perspective and made concrete enough to facilitate the implementation, integration and maintenance.

The framework is modular where each component has a clear responsibility. The rationale behind this architectural decision is that it needs scalability, maintainability, and conceptual clarity, especially since the system uses the multidisciplinary approach that integrates simulation logic, behavioural analysis, data processing, and user interaction.

The Simulation Engine is the heart of the system and it can be said to coordinate the implementation of social engineering scenarios. The Simulation Engine loads the data layer with scenario definitions, schedules simulation sessions and also coordinates the provision of the simulated artefacts of attack to the end users. Notably, this element will be run in a controlled environment to ensure that all the simulations are not connected to actual organisational systems but the presentation and timings are kept realistic.

Intimately related to the Simulation Engine is the Scenario Management Module that manages simulation scenario creation, modification, and storage. The administrators of this module are given the opportunity of defining the attack vectors, the level of difficulty, and contextual metadata, which are then consumed by the Simulation Engine when it is running. The architecture allows scenario management to be decoupled with execution logic in order to reuse scenarios in more than one simulation and to refine scenarios through iteration without interfering with system behavior.

The Data Collection Module provides the analysis of the user interaction created in the sessions of simulation. This element serves as a mediator between user facing interfaces and the analytical elements of the system. It logs behavioural events, e.g. clicks, credential submissions, and reporting behaviour and stores the behavioural events persistently according to the described data model. Timing of events is also found in the Data Collection Module, as events are linked to the corresponding user and simulation session, and contextual integrity is maintained.

The Detection and Evaluation Module does behavioural evaluation, which is one of the most important analytical framework components. This module takes raw interaction data and uses predefined rules and thresholds to categorize the user actions as safe, risky and critical. Separable logic of detection enables evaluation choices to be revised or enhanced without reference to simulation delivery or data storing processes. Consequently, there is the ability of the system to

develop and be in a position to accept more advanced methods of detection without necessarily having to restructure the architecture in any way.

Feedback Generation Module is in charge of converting evaluation results to user oriented explanations. After the classification of an action of a user is complete, this component produces contextual feedback explaining how the classification got to the conclusion and provides indicators that might have been used to signal the simulated attack. It is a key module in fulfilling the education goals of the framework because it has a direct connection between behavioural assessment and learning and awareness.

The Analytics Module does analytical aggregation and trend analysis. This element works with raw interaction data as well as metrics calculated, and indicators including the average reaction time, reporting rates, and click-through rates are calculated. The Analytics Module allows summaries in real-time as well as longitudinal analysis with multiple simulation sessions, which allows administrators to see behavioural change across time and be able to determine risk patterns that persist.

The Reporting and Visualisation Module will give the administrators access to the analytic output in both dashboards and structured reports. This element gets aggregated data in the Analytics Module and renders it in a format that can be used to make decisions, evaluate training and assess risks in an organisation. The system allows greater presentation flexibility of results without analytical inconsistency, because it decoupling of reporting logic and analytical computation.

The Authentication and Authorisation Module deals with access control and user identity management. This element guarantees that administrative functions and view of analytical results or setting simulation scenarios are available to authorised users. The role-based access control is implemented to differentiate between administrators and end users to accommodate security and usability demands.

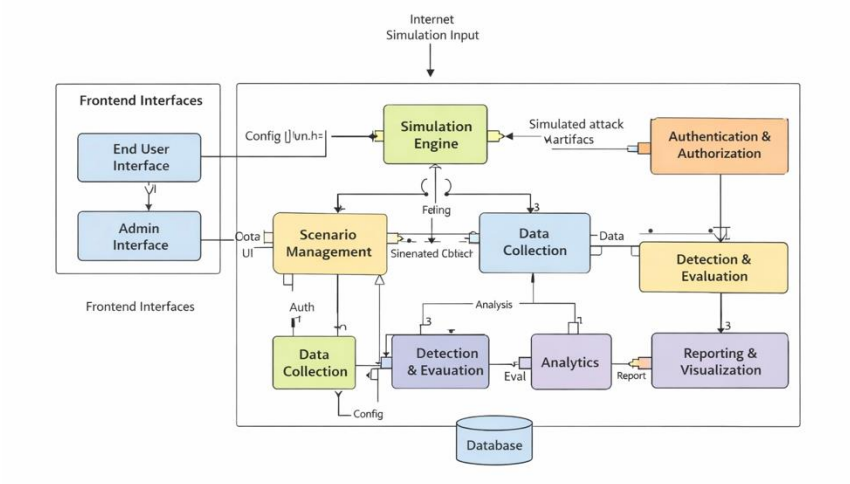

Figure 4.7: Component Diagram of the Simulation-Based Cybersecurity Framework

4.5 Interface and API Design

The interfaces of the system must be clearly defined to make sense of how each piece of the framework is connected with each other and how the system is interacted with. Although the component architecture outlines the structural breakdown of the framework, interface and API design outlines the operational contracts, which allow the coordinated behaviour of clients on the front-end and backend services and analytical modules. This subsection consequently records the main interfaces that the system reveals as well as how information moves around components during execution.

The service-oriented nature of the interaction model used in the framework where communication between the front-end and back-end is accomplished by the use of RESTful application programming interfaces (APIs). This is a style that encourages loose integration among parts of the system, extends its functionality easily in the future and makes it possible to integrate alternative client applications without altering the core business logic.

The interfaces that face the user are classified into two main sections; the end-user interface and the administrative interface. End-user interface will provide simulated artefacts of the attack, user

responses and immediate feedback after the user takes actions. Conversely the administrative interface allows authorised staff to customise scenarios, start simulation sessions and view analytical reports. Both interfaces only communicate with the back-end via authenticated API calls, and on this way, maintain a uniform and secure access model.

The system opens a series of logical API endpoints at the back-end level that are grouped based on functional responsibility. Authentication-based endpoints deal with the login of the users, session control, and role authentication. These interfaces will make sure that only authorised users can access sensitive administrative processes whereas the usual participants can only engage in simulation-related interactions. The authentication tokens provided by this service are carried through to future API requests and checked by middleware elements before the requests are handled further.

Simulation scenarios can be created, updated, accessed, and switched off by the administrators using scenario management interfaces. The requests which are made over these endpoints have structured payloads that explain the characteristics of the scenario like attack type, level of difficulty, and metadata related to the scenario. Successful operations are usually responded to with responses; descriptive error messages are usually received in the event of invalid input or access violation. This is a clear agreement between the client and the server, which avoids ambiguity and enables sound front-end validation.

Execution of simulation is orchestrated by a specialized group of interfaces using which the authorised persons can instigate simulation sessions and also track their progress. When a simulation-run is initiated, the front-end makes a request with the references to the chosen scenario and the target user group. The back-end does this by creating a new simulation session and initiation of the Simulation Engine that then provides simulated artefacts of attacks to participants. Structured responses are used to send status updates and metadata on executions, which the administrative interface can use to monitor running simulations.

Action-reporting interfaces on the Data Collection Module transfer the user interaction data to the back-end. Every request is associated with a discrete user action and it contains parameters indicating the type of action, time when it was performed, and the simulation session. The interfaces will be made lightweight and robust at the same time so that the events of interaction are

always reliably acquired even in an unstable network environment. Validation mechanisms: These make certain that invalid or illegitimate requests are rejected without harming system integrity.

Reporting interfaces get the access of analytical results and aggregated metrics which retrieve the precomputed indicators of the Analytics Module. Such interfaces allow the administrator to request metrics with filtering and aggregation parameters, and these allow them to request metrics at various levels of granularity, like at the level per simulation session or at the level of multiple simulation sessions. The responses are sent in structured formats, which can be visualised and further analysed by the reporting dashboard.

In all interfaces, error processing is based on a standard strategy where meaningful status codes and descriptive messages are sent to the client. This design option improves usability, makes it easier to debug, and graceful degradation should some unforeseen conditions occur. The transparency, interoperability and maintainability of the structure are provided by clearly documenting these interface contracts.

4.6 Implementation Details

This subsection will give a comprehensive report of the implementation of the proposed simulation-based cybersecurity framework, which will transform the conceptual design and architectural requirements discussed in the previous sections into a functional software. It is a requirement of master level because it requires one to document the decisions made during implementation not just to show that the system is operational, but to indicate that the choice of constructions was based on the conscious and technically well-founded decisions.

The framework was done in a modular, service oriented manner that is consistent with the component architecture that has been explained above. This enables single subsystems to be designed, tested and repaired in their own right but yet work together as a complete whole.

The back-end of the system was developed on the basis of Node.js, Express.js. The choice of node.js was based on its non-blocking nature and event-driven architecture that it has that is specifically suitable when dealing with concurrent user interactions during simulation sessions. Express.js is a simple but customizable framework to create RESTful routes, middleware, and request processing logic to allow the separation of routing, authentication, and business logic layers.

The backend project is structured in a hierarchical distribution of directories, which is a reflection of the break up of functions of the system. Core modules are divided into separate directories that are based on authentication, scenario management, simulation execution, data collection, analytics, and reporting. This organisation enhances the readability of the code and aid in the maintainability by making sure that the functionality relating to the code is encapsulated in distinct modules. Application logic is not mixed with configuration files, including environment variable definitions and parameters connecting to a database, which are separated to minimize a dependence between application logic and configuration and support deployment in varying environments.

The interface of the framework consisted of the typical web technologies, such as HTML, CSS, and JavaScript and was aimed at being clear and responsive and easy to use. The administrative interface and end-user interface are separated by logic and have different functional roles. Whereas the end-user interface is more concerned with realism and minimum distraction in the process of interaction with the simulation, the administrative interface is more focused on the clarity of information, well-organized navigation, and the availability of analytical data.

The interaction between the frontend and the backend is actualised completely using the RESTful APIs mentioned in the former subsection. This design choice guarantees that there is a loose coupling between presentation and application logic and the frontend can independently develop even without the services of the backend. Client side validation is done prior to transmissions, and server side validation and sanitisation are used to give extra protection against malformed or unauthorised input.

The database system used to implement data persistence is in line with the schema outlined above. The access to the database is mediated by means of a special data access layer, which separates query logic under the low-levels with business rules at the upper-levels. Such an abstraction makes migration to alternative storage technologies in the future easier and facilitates the systematic management of errors. The integrity of transactions is maintained in the data recorded on user activities and simulation outcomes such that analytical results are determined utilizing full and consistent datasets.

The implementation issues around the Simulation Engine, which manages the implementation of the scenarios and the tracking of the user interaction are one of the key elements of implementation. The engine is done as a service, which initiates simulation sessions, arranges to deliver simulated

attack artefacts and tracks user responses. The engine itself has session state data which identifies users, scenarios and captured actions. This state management model is created so that the execution of concurrent simulations is not interrupted.

The behavioural evaluation is enforced in the Detection and Evaluation Module that uses rule-based logic to categorise user behaviour. As an example, clicking an nasty link or providing credentials is associated with the risk categories that are predefined according to the scenario-related thresholds. These classifications are done right after action capture and they allow generation of feedback in time and precise calculations of metrics. The reason behind selecting the rule-based approach is its transparency and interpretability, which is especially significant in the case of education and training oriented context.

Aggregation routines that act on stored interaction data are implemented to provide reporting and analytics functionality. These routines calculate measures like click through rate and reporting rate by walking over the records of actions within a particular simulation session. The findings are stored in a persistent manner in order to facilitate easy retrieval and visualisation without necessarily computing the results again. This architecture compromises between computational and analytical flexibility.

Security has been taken into account during the implementation process. The security system operates on authentication and authorisation built in middleware components to intercept incoming requests and authenticate access rights to user roles. Authorised administrators can only access sensitive operations, including scenario configuration and report access. Also, client and server interactions are engineered to facilitate secure transportation mechanisms which minimize vulnerability to espionage or hacking.

In general, there is a wiseism in the execution of the system requirements in respect of the architectural design and technical execution. This subsection shows that the framework is not just a conceptual framework by recording the project structure, technology stack and major implementation choices; it is a carefully engineered framework that can be evaluated through experiments and extended to other areas to provide a comprehensive view of its capability and applicability.

4.7 Environment, Deployment and Configuration.

The description of the environment where the framework will be executed and the deployment process must be clear to show that the proposed framework is not only theoretically good but also can be practically implemented and replicated. The following subsection thus describes the environment during which the simulation based cybersecurity framework will be used, the requirements during configuration, and the procedure to be followed during the deployment.

In the development and testing, the system was rolled out under a controlled environment that was aimed at closely simulating an actual organisational IT configuration but was not isolated with production systems. The framework was implemented in a standard server system with a common operating system, which had a consistent and representative background on which to carry out simulation and testing processes. This deployment option assures that the behaviour of the system that is observed during evaluation is in line with realistic conditions that it would be in its operational environment.

The backend services were deployed on a local server environment, and the Node.js runtime and its dependencies were installed and maintained by a package manager. Explicit declaration of all the third-party libraries and frameworks needed by the system was done to make sure that the application environment was reproducible across various machines. Environment specific variables like database connection credentials and security related configuration values were externalised by use of environment variables instead of being hard coded into the application logic. This will increase security and portability.

The database system was implemented as a dedicated service and was set up according to the schema discussed above. The first task in database setup was to create the necessary tables or collections, impose key constraints and ensure connection with the application layer. This design guarantees an adequate data persistence and provides stable results in analysis when running the simulation.

Frontend elements of the structure were implemented with the backend services and were served with the help of a regular web browser. The model of this deployment does not require any specialised client software and makes participation in the simulation exercise easier on the part of the users. The application server served the role of serving the static assets, and the generator of

dynamic content was done through authenticated API interactions with a set of behind the scenes services.

The system configuration is made in a well-defined order. Once the necessary dependencies are installed, environment variables are declared to indicate runtime parameters like server ports, database endpoints and authentication settings. Database is then initialised and the application services are started in the corresponding mode of execution. Such an organized arrangement process makes it possible to make the system deployable by technical staff with a minimum of manual interventions.

Even though the prototype implementation did not necessitate any containerisation technologies like Docker, the modular architecture and externalised configuration model embraced by the framework can be deployed into a container based architecture. This compatibility enables the subsequent versions of the system to use containerisation to achieve a better scalability, isolation and distribution ease.

This subsection shows that the proposed framework is operationally viable by documenting the environment, deployment and configuration process and proves that experimental results of the framework can be replicated or expanded to further work.

4.8 Detection Logic, Testing and Evaluation

4.8.1 Experimental Setup and Metrics

This subsection explains the logic on the internal side of the framework to test the behaviour of the users during simulated phishing and give the approach taken to test and evaluate the systems in terms of functionality and performance validation. It is necessary to give a clear explanation of the detection mechanisms and evaluation of this through empirical means which would prove that the framework does not just perform simulations but creates meaningful and measurable analysis results.

The framework has a detection logic with the aim of organizing the user actions according to their security implications within the framework of each simulation scenario. When simulating, all interactions carried out by a user will be recorded by the Data Collection Module and sent directly to the Detection and Evaluation Module. Those behaviours, e.g. clicking on embedded links,

entering credentials, not paying attention to simulated messages, and reporting suspicious information are compared with a set of rules which is predetermined with the active scenario. These guidelines are contextual and the framework reconfigures its evaluation criteria to new attack vectors and difficulty levels.

The set of user actions is classified into behavioural classes having different risk of security. As a case in point, the interactions that imply engagement with a simulated malicious artefact are considered to be risky behaviour, and the interactions that include reporting the artefact or avoiding interaction during a specific time span are regarded as safe behaviour. Such a rule-based method was chosen to make the results trans and interpretable, which are essential conditions in training-based cybersecurity systems. The framework assists the administrators and researchers to have a clear understanding of the derivation of the behavioural outcomes by evading opaque decision mechanisms.

According to such classifications, the framework calculates a series of quantitative measurements which are applied towards testing user susceptibility and general organisational awareness. The rate of click-through is determined as the percentage of users who dealt with a simulated malicious object as opposed to the number of users that were present in a given simulation session. The reporting rate is the percentage of users that proactively reported the simulated attack using the interface that was provided. The reaction time is calculated as the time that passes between the time the simulated artefact has been offered to the user and the time at which the user records the first response. These measures are calculated with the help of aggregated action records found in the database and are related both to individual simulation sessions and to particular scenarios.

In order to achieve accuracy and consistency, metric calculation is achieved on the completion of every simulation session and the results are stored persistently. Such design prevents re-calculation, and enables comparison of historical overcomes of various simulation runs. The metrics stored are the basis of analytical visualisation and longitudinal evaluation of behavioural patterns in respect of time.

The implementation was also tested at various levels, to ensure that the implementation was correct and robust. The unit testing was on the individual modules such as scenario management, data collection and metric computation modules. These testing ensured that every module was working in its intended purpose under normal conditions and under the boundary conditions. Integration

testing followed, and it was tested that the modules interacted as desired i.e. data flow between the Simulation Engine into the Analytics Module. Specific emphasis was made on proper propagation of user activities and integrity of records kept.

System-level testing was a test of the framework as a system in realistic simulation conditions. Added simulation sessions were conducted with involving various users and scenarios to ensure that overall end-to-end workflow, including scenario setup and running, reporting and analysis, functioned as required. Simple performance checks were also made in order to guarantee that the system was capable of supporting multiple user interactions at the same time without losing responsiveness.

An experimental test was also performed alongside the functional testing to determine the capability of the framework to ensure that meaningful behavioural data were captured. The main research question that informed this assessment was whether the framework would be effective in measuring the susceptibility of users to phishing attacks as well as distinguishing between risky and safe behavioural patterns across simulation conditions. There was an exposure of participants to a collection of pre-implemented phishing simulations of typical attack methods. The interactions between the users were automatically captured and metrics calculated after the end of every session.

Quantitative tables and graphical illustrations were used to summarise the results of the evaluation including measures of click-through rate, reporting rate and average reaction time. These findings have revealed that there are observable variations in user behaviour in different situations, which means that the framework has been effective in capturing variations in security awareness and response patterns. Although the appraisal was done in a controlled set up and with a small number of participants, the results are a first step towards the effectiveness of the framework applied in the analytical process.

The evaluation has a number of shortcomings that need to be mentioned. The size of the experiment was limited by the practical aspects and controlled environment might not be the best representation of the real organisational behaviour. However, the findings indicate that the framework can be considered as a valid simulation and analysis tool and extended to larger and more diverse populations of users in future studies.

4.8.2 Quantitative Results

The evaluation involved 24 participants drawn from non-technical and semi-technical backgrounds. Each participant completed three simulation rounds involving phishing and baiting scenarios. Metrics collected included click-through rate, reporting rate, and average reaction time.

Table 4.1: Summary of Experimental Results

Metric	**Round 1**	**Round 3**	**Change**
Click-through rate	41.7%	16.7%	-25.0%
Reporting rate	29.2%	66.7%	37.5%
Average reaction time (seconds)	18.4	9.6	-8.8

The results indicate a substantial improvement in user behaviour over successive simulation rounds. The click-through rate decreased by 25 percentage points, suggesting that users became more cautious when interacting with suspicious content. At the same time, the reporting rate more than doubled, indicating increased awareness and proactive defensive behaviour. The reduction in average reaction time reflects faster recognition of potential threats. These findings provide empirical support for the hypotheses that simulation-based exposure and integrated feedback mechanisms enhance detection capability and behavioural resilience, thereby demonstrating the practical usefulness of the proposed framework.

4.9 Chapter Summary

In this chapter, the design, implementation and evaluation of the proposed cybersecurity awareness framework based on simulation was well documented. The chapter started with a top-level architectural view of the system and gradually narrowed down the system description using formal use case analysis, data modeling, component and interface design, and detailed implementation concerns. This systematic methodology made sure that the framework is not defined conceptually, but also as a deployable system.

The chapter described the ways in which user interactions on the system are enabled using a realistic and accessible interface, behavioural data is persistently stored and structured using a well-defined data model, and the modular system constituents can interact with each other using clearly defined interfaces and APIs. Implementation choices were also supported with regard to scaling, maintainability, and security, and deployment and configuration choices indicated the viability and reproducibility of operations of the system.

In addition, the chapter explained the detection logic, which was employed to identify the user behaviour when under simulated attacks and the testing and evaluation procedures, which were employed in order to check the functionality and analytical effectiveness of the system.

Overall, this chapter established that the proposed framework is technically sound, ethically grounded, and capable of supporting systematic cybersecurity training and evaluation. The detailed documentation provided herein forms a solid foundation for interpretation of results and broader discussion in the subsequent chapter.

CHAPTER FIVE: CONCLUSION AND FUTURE WORK

This thesis addressed the growing challenge of social engineering attacks by proposing and evaluating a simulation-based framework designed to enhance detection capabilities and user preparedness. The study was motivated by the observation that many successful cyberattacks exploit human behaviour rather than technical vulnerabilities, and that existing security solutions often treat awareness training and detection mechanisms as separate concerns.

5.1 Answer to the Main Research Problem

The main research problem asked: What are the best practices to design and implement an effective simulation-based framework to detect and prevent social engineering attacks?

Based on the design, implementation, and experimental evaluation of the proposed framework, the study demonstrates that an effective solution should combine realistic attack simulation, continuous user interaction, automated behavioural detection, and immediate feedback mechanisms within a unified system. The results indicate that simulation-based exposure, when integrated with detection logic and performance analytics, significantly improves users' ability to recognise and appropriately respond to social engineering attempts.

5.2 Verification of Hypotheses

The experimental results support the leading hypothesis that a simulation-based framework can enhance detection and defence against social engineering attacks.

H1, stating that comprehensive identification of attack types improves simulation accuracy, was confirmed through the successful modelling of phishing, spear-phishing, and baiting scenarios that users perceived as realistic.

H2, concerning the role of a well-designed simulation environment in facilitating realistic testing, was supported by measurable changes in user behaviour across repeated simulations.

H3, proposing that integrated detection and defence mechanisms improve organisational readiness, was confirmed by increased reporting rates and reduced reaction times observed during the evaluation.

H4, predicting measurable improvement in attack mitigation, was validated through quantitative reductions in click-through rates and faster identification of malicious content.

5.3 Contribution of the Study

The main contribution of this thesis lies in the development of a holistic, human-centred simulation framework that bridges the gap between cybersecurity awareness training and automated detection. Unlike many existing tools that focus solely on phishing awareness, the proposed framework integrates multiple attack vectors, behavioural logging, and feedback mechanisms within a modular architecture. The study also contributes empirically by demonstrating how simulation data can be used to assess behavioural resilience and guide targeted improvements in organisational security practices.

5.4 Limitations

Despite its contributions, the study has several limitations. The experimental evaluation was conducted on a limited number of participants, which restricts the generalisability of the results. The simulated environment, although realistic, cannot fully capture the complexity and emotional pressure of real-world attacks. In addition, the detection logic relied primarily on rule-based behavioural indicators rather than advanced machine-learning techniques, which may limit adaptability to novel attack patterns.

5.5 Directions for Future Work

Future research should extend the framework by involving larger and more diverse participant groups to improve statistical validity. The integration of machine-learning models for adaptive detection and personalised training paths represents a promising direction. Further work could also explore immersive technologies such as virtual or augmented reality to simulate physical and hybrid social engineering attacks. Finally, tighter integration with enterprise security systems, including SIEM platforms, would enhance real-time operational applicability.

BIBLIOGRAPHY

(a) Documents

Fuertes, W., Arévalo, D., Castro, J., Ron, M., Estrada, C., Andrade, R., Peña, F. & Benavides, E., 2022. *Impact of social engineering attacks: A literature review.* In: Lecture Notes in Networks and Systems, pp. 23–38. https://doi.org/10.1007/978-981-16-4884-7_3

Mollazehi, A., Abuelezz, I., Barhamgi, M., Khan, K. & Ali, R., 2024. *Do Cialdini's persuasion principles still influence trust and risk-taking when social engineering is knowingly possible?* In: Lecture Notes in Computer Science, pp. 245–261. https://doi.org/10.1007/978-3-031-59465-6_17

Verizon, 2023. *2023 Data Breach Investigations Report – Public Sector Snapshot.* Available at: https://www.verizon.com/business/resources/Ta5a/reports/2023-dbir-public-sector-snapshot.pdf [Accessed 3 September 2025].

(b) Books

(No standalone books in the bibliography.)

(c) Periodicals

Adekugbe, A. & Ibeh, C., 2024. Utilizing comprehensive data dashboards to improve service delivery: Insights from U.S. case studies. *International Journal of Frontiers in Engineering and Technology Research*, 6, pp. 008–018. https://doi.org/10.53294/ijfetr.2024.6.2.0030

Adu-Manu, K., Ahiable, R., Mensah, E. & Sarpong, K., 2023. Phishing attacks in social engineering: A review. *Journal of Cyber Security*, 29. https://doi.org/10.32604/jcs.2023.041095

Akella, D., 2010. Learning together: Kolb's experiential theory and its application. *Journal of Management & Organization*, 16, pp. 100–112. https://doi.org/10.5172/jmo.16.1.100

Alhuzali, A., Alloqmani, A., Aljabri, M. & Alharbi, F., 2025. In-depth analysis of phishing email detection: Evaluating the performance of machine learning and deep learning models across multiple datasets. *Applied Sciences*, 15(6), p. 3396. https://doi.org/10.3390/app15063396

Alkhalil, Z., Hewage, C., Nawaf, L. & Khan, I., 2021. Phishing attacks: A recent comprehensive study and a new anatomy. *Frontiers in Computer Science*, 3, p. 563060. https://doi.org/10.3389/fcomp.2021.563060

Almutairi, B. & Alghamdi, A., 2022. The role of social engineering in cybersecurity and its impact. *Journal of Information Security*, 13, pp. 363–379. https://doi.org/10.4236/jis.2022.134020

Aminu, M., Akinsanya, A., Oyedokun, O., Dickson, A. & Dako, ., 2024. Enhancing cyber threat detection through real-time threat intelligence and adaptive defense mechanisms. *International Journal of Computer Applications Technology and Research*, 13, pp. 11–27. https://doi.org/10.7753/IJCATR1308.1002

Aparna, G., Krishna, B., Reddy, C., Kola, L. & Akshitha, M., 2024. Phishing simulations. *International Journal of Novel Research in Engineering & Pharmaceutical Sciences*, 3, p. 866.

Aslan, Ö., Aktuğ, S., Ozkan, M., Yılmaz, A. & Akin, E., 2023. A comprehensive review of cybersecurity vulnerabilities, threats, attacks, and solutions. *Electronics*, 12, pp. 1–42. https://doi.org/10.3390/electronics12061333

Budnarowski, D., Jereczek, D., Detka, K. & Wieczorek, I., 2025. Application of artificial intelligence and virtual reality in soft skills training with a modeled personality. *Applied Sciences*, 15(16), p. 9067. https://doi.org/10.3390/app15169067

Chatchalermpun, S. & Daengsi, T., 2021. Improving cybersecurity awareness using phishing attack simulation. *IOP Conference Series: Materials Science and Engineering*, 1088, p. 012015. https://doi.org/10.1088/1757-899X/1088/1/012015

Chathuranga, S., Jayasinghe, S., Antucheviciene, J., Wickramarachchi, R., Udayanga, N. & Weerakkody, W.A.S., 2023. Practices driving the adoption of agile project management

methodologies in the design stage of building construction projects. *Buildings*, 13(4), p. 1079. https://doi.org/10.3390/buildings13041079

Chauhan, A., Begum, J., Lavanya, K.M., Gupta, A., Ghosh, S. & Kulkarni, S., 2024. Experiential learning of active learning strategies in mentor-learner web-based discussions: A perceptions study. *International Journal of Applied & Basic Medical Research*, 14(4), pp. 258–265. https://doi.org/10.4103/ijabmr.ijabmr_277_24

Ekpobimi, H., Kandekere, R. & Fasanmade, A., 2024. Front-end development and cybersecurity: A conceptual approach to building secure web applications. *Computer Science & IT Research Journal*, 5, pp. 2154–2168. https://doi.org/10.51594/csitrj.v5i9.1556

Elendu, C. et al., 2024. The impact of simulation-based training in medical education: A review. *Medicine*, 103(27), p. e38813. https://doi.org/10.1097/MD.0000000000038813

Folorunso, A., Wada, I., Samuel, B. & Mohammed, V., 2024. Security compliance and its implications for cybersecurity. *World Journal of Advanced Research and Reviews*, 24, pp. 2105–2121. https://doi.org/10.30574/wjarr.2024.24.1.3170

Gilbert, C. & Gilbert, M., 2024. The impact of AI on cybersecurity defense mechanisms: Future trends and challenges. *Global Scientific Journal*, 12, pp. 427–441. https://doi.org/10.11216/gsj.2024.09.229721

González-Granadillo, G., González-Zarzosa, S. & Díaz, R., 2021. Security information and event management (SIEM): Analysis, trends, and usage in critical infrastructures. *Sensors*, 21(14), p. 4759. https://doi.org/10.3390/s21144759

Heß, J. & Graffi, K., 2025. Detection of malicious Office Open Documents (OOXML) using large language models: A static analysis approach. *Journal of Cybersecurity and Privacy*, 5(2), p. 32. https://doi.org/10.3390/jcp5020032

Jaramillo-Mediavilla, L. et al., 2024. Impact of gamification on motivation and academic performance: A systematic review. *Education Sciences*, 14(6), p. 639. https://doi.org/10.3390/educsci14060639

Kasri, W. et al., 2025. From vulnerability to defense: The role of large language models in enhancing cybersecurity. *Computation*, 13(2), p. 30. https://doi.org/10.3390/computation13020030

Kavak, H. et al., 2021. Simulation for cybersecurity: State of the art and future directions. *Journal of Cybersecurity*, 7. https://doi.org/10.1093/cybsec/tyab005

Khadka, K. & Ullah, A.B., 2025. Human factors in cybersecurity: An interdisciplinary review and framework proposal. *International Journal of Information Security*, 24. https://doi.org/10.1007/s10207-025-01032-0

Korteling, J.E.H., Paradies, G.L. & Sassen-van Meer, J.P., 2023. Cognitive bias and how to improve sustainable decision-making. *Frontiers in Psychology*, 14, p. 1129835. https://doi.org/10.3389/fpsyg.2023.1129835

Lugo, R.G. et al., 2023. Editorial: The human factor in cyber security education. *Frontiers in Education*, 8, p. 1277282. https://doi.org/10.3389/feduc.2023.1277282

Mallick, M. & Nath, R., 2024. Simulating cyber threats: A review of AI-powered attack simulators for enhanced cybersecurity. *International Journal of Cybersecurity Research*, 197, pp. 14–54.

Morić, Z. et al., 2025. Evaluating end-user defensive approaches against phishing using education and simulated attacks in a Croatian university. *Journal of Cybersecurity and Privacy*, 5(3), p. 38. https://doi.org/10.3390/jcp5030038

Mouton, F., 2018. Social engineering attack detection model. *Journal of Information Warfare*, 17(4), pp. 90–110.

Pedersen, K.T. et al., 2025. Deepfake-driven social engineering: Threats, detection techniques, and defensive strategies in corporate environments. *Journal of Cybersecurity and Privacy*, 5(2), p. 18. https://doi.org/10.3390/jcp5020018

Salman, H. & Alsajri, A., 2023. The evolution of cybersecurity threats and strategies for effective protection: A review. *SHIFRA*, pp. 1–13. https://doi.org/10.70470/SHIFRA/2023/009

Salahdine, F. & Kaabouch, N., 2019. Social engineering attacks: A survey. *Future Internet*, 11(4), p. 89. https://doi.org/10.3390/fi11040089

Siddiqi, M.A., Pak, W. & Siddiqi, M.A., 2022. A study on the psychology of social engineering-based cyberattacks and existing countermeasures. *Applied Sciences*, 12(12), p. 6042. https://doi.org/10.3390/app12126042

Syafitri, W. et al., 2022. Social engineering attacks prevention: A systematic literature review. *IEEE Access*, 10, pp. 1–20. https://doi.org/10.1109/ACCESS.2022.3162594

Tanti, R., 2024. Study of phishing attack and their prevention techniques. *International Journal of Scientific Research in Engineering and Management*, 8, pp. 1–8. https://doi.org/10.55041/IJSREM38042

Tassinari, M., Aulbach, M.B. & Jasinskaja-Lahti, I., 2022. The use of virtual reality in studying prejudice and its reduction: A systematic review. *PLOS ONE*, 17(7), p. e0270748. https://doi.org/10.1371/journal.pone.0270748